

GOVERNMENT OF ANDHRA PRADESH

ABSTRACT

IT,E&C Department – Andhra Pradesh Cyber Security Framework (APCSF) – For effective implementation of the 'AP Cyber Security Policy 2017' across the State – Orders – Issued.

**INFORMATION TECHNOLOGY, ELECTRONICS & COMMUNICATIONS (INFRA)
DEPARTMENT**

G.O.MS.No.18

Dated.06.03.2019

Read the following

1. “National Cyber Security Policy in 2013”, notified in the Gazette of India Extraordinary No. 143, dated.02.07.2013.
2. G.O.MS.No.2, IT,E&C (Infra) Department, Dated.01.03.2017.
3. eOffice NF No.APTS/CS/CyberSOC/04/2017.
4. G.O.MS.No.4, IT,E&C (Infra) Department, Dated.10.01.2019.
5. G.O.MS.No.6, IT,E&C (Infra) Department, Dated.25.01.2019.

ORDER

The MD, APTS vide efile 3rd read above has stated that, the Government of India had notified the “National Cyber Security Policy in 2013”. The National Policy lays down a number of strategies for realizing the vision of ‘building a secure and resilient cyberspace for citizens, businesses and Government’. The State of Andhra Pradesh has been a pioneer in the use of ICTs extensively for delivery of public services and felt the need to establish “Andhra Pradesh Cyber Security Policy”, to complement and supplement the National Cyber Security Policy 2013, and issued “Andhra Pradesh Cyber Security Policy 2017” (APCSP), vide G.O 2nd cited.

2. Government has identified the M/s APTS Ltd. as a Nodal Agency on behalf of IT,E&C Department for implementing the APCSP. Accordingly, APTS has established the AP Cyber Security Operation Centre at Vijayawada on 23.04.2018. APCSP proposes establishing Cyber Security Framework (CSF), Security Architectures for securing Government Cyber Space, Andhra Pradesh Computer Response Team (APCRT), Security Operations Centre, Security Assurance Framework and Andhra Pradesh Information Sharing Network (APISN). The MD, APTS has submitted the Andhra Pradesh Cyber Security Framework (APCSF) for effective implementation of the 'AP Cyber Security Policy 2017' across the State.

3. Government after careful examination of the matter hereby approve the Andhra Pradesh Cyber Security Framework (APCSF) for effective implementation of the 'AP Cyber Security Policy 2017' across the State which is appended to these orders in Annexure.

4. The Managing Director, APTS shall take further necessary action accordingly.

(BY ORDER AND IN THE NAME OF THE GOVERNOR OF ANDHRA PRADESH)

**K. VIJAYANAND
PRINCIPAL SECRETARY TO GOVERNMENT**

(P.T.O)

To:

The Managing Director, APTS, Vijayawada

All the members of Apex Committee

All the members of Advisory Board

All the members of Sub-Committee on Critical Information Infrastructure

All the members of Sub-Committee on Capacity Building

All the members of Sub-Committee on Cybercrime and Law Enforcement

All the Spl. Chief Secretaries/ Prl. Secretaries/ Secretaries/ Spl. Secretaries to Government

All the Heads of Departments

All the District Collectors & Magistrates, AP

All the Societies/Institutions/Autonomous Bodies

The C.E.O., RTGS

All the Vice Chancellors of Universities in Andhra Pradesh

The Commissioner, I&PR, Vijayawada

Copy to:

The P.S. to Hon'ble Chief Minister, Andhra Pradesh

The O.S.D. to Hon'ble Minister for IT,E&C

The P.S. to Chief Secretary to Government of Andhra Pradesh

//FORWARDED: BY ORDER//

SECTION OFFICER

APPENDIX

to G.O.MS.No.18, IT,E&C (Infra) Department, Dated.06.03.2019



Government of Andhra Pradesh

Cyber Security Framework (CSF)

March 2019

Message from Chief Minister

I am delighted to note that Andhra Pradesh is ready with a comprehensive Cyber Security Framework, a first by any state in the country. Andhra Pradesh has been in the forefront of IT initiatives and leads India in the implementation e-Governance initiatives and the use of e-Office systems state-wide.

As the state evolves and industries set up base here, Andhra Pradesh will slowly but relentlessly become part of the larger global economy and a connected world. This brings with it the ever present danger of cyber threats.

The stability and security of Government's critical infrastructure and the safety of the people of Andhra Pradesh are important to us. Ability to combat cyber threats with a mature Cyber Security Framework is not only pivotal but will also provide the State of Andhra Pradesh a unique value proposition of being a cyber-safe destination.

The Cyber Security Framework gives us the ability to clearly understand emerging threats, and continuously monitor our IT systems. This is the first step to help us put our defenses in place to protect from malicious actors.

On behalf of the Government of Andhra Pradesh, I commend this initiative and sincerely hope that businesses look towards us as the next emerging cyber security destination in the world.

Table of Contents

1	Introduction	1
	1.1 About the Document	1
	1.2 Purpose	2
	1.3 Intended Audience	2
	1.4 Applicability	2
2	Overview of AP – CSF	2
	2.1 AP CSF and AP Cyber Security Policy	4
3	Components of AP – CSF	4
	3.1 Unified Control Matrix	4
	3.2 Inherent Risk	5
	3.3 Frame Work Profile	6
	3.4 Cyber Security Environment	6
4	Control Universe	6
	4.1 Controls	7
5	Industry Sector Specific Requirements	79
6	Audit and Assurance Framework	51
	6.1 Guidelines for Audit & Assurance Function	52
7	Implementation Imperatives	53
	7.1 Step by Step Approach	53
	7.1.1 Identify applicable controls as per business requirements	53
	7.1.2 Create Cybersecurity Policies	54
	7.1.3 Evaluate Inherent Risk for business and create current profile	54
	7.1.4 Create a Target Profile	54
	7.1.5 Determine, Analyze and Prioritize gaps	54
	7.1.6 Implement Controls for prioritized gaps	54
	7.1.7 Continuous Improvement	54
	7.2 Implementation Governance	55
	7.2.1 Apex Committee	55
	7.2.2 Advisory Board	56
	7.2.3 Sub-Committees for Implementation	57
	7.2.3.1 Sub-Committee on Critical Information Infrastructure	57
	7.2.3.2 Sub-Committee on Capacity Building	58
	7.2.3.3 Sub-Committee on Cybercrime and Law Enforcement	58
	7.3 Supporting guidelines and tool kits	59
	7.4 Nodal body to assist implementation	59
	7.5 Annexure	59
	7.5.1 Unique Identifiers for Controls	59

Acronyms

AP-CSOC	Andhra Pradesh Cyber Security Operations Centre
CERT In	Indian Computer Emergency Response Team
CII	Critical Information Infrastructure
COBIT	Control Objectives for Information and Related Technology
CSF	Cyber Security Framework
ICS	Industrial Control Systems
IoT	Internet of Things
IRDAI	Insurance Regulatory and Development Authority of India
ISO	International Organization for Standardization
IT	Information Technology
IT Act	Information Technology Act 2000 as amended
NCIIPC	National Critical Information Infrastructure Protection Centre
NIST	National Institute of Standards and Technology
PCI-DSS	Payment Card Industry Data Security Standard
RBI	Reserve Bank of India
UCM	Unified control matrix
UIDAI	Unique Identification Authority of India

1. Introduction

Increased digitization, ubiquitous connectivity, sophistication of cyber-attacks and their cyber-physical impacts have pushed cyber security planning and protection from an operational concern of Technology unit to strategic agenda of both Governments and Corporates.

Seeking rapid growth and development, the Government of Andhra Pradesh envisions remolding and redefining the trajectory of the State through Information and Communication Technologies. To successfully combat cyber threats and address the rising concerns in the domain, the Government of Andhra Pradesh has notified the AP Cyber Security Policy 2017 (G.O.MS No.2 ITE&C Dept. dated 030117) with the Vision – “to create a robust cyber ecosystem, wherein the citizens transact online securely and take steps to protect their identity, privacy and finances online, the businesses conduct their operations without any disruption or damage and the Government ensures that its data and ICT systems are secure”.

As depicted in the Figure 1, the State aims to build strong cyber security capabilities through eight ‘building blocks’ that will work in tandem through a smooth network of information and knowledge sharing, while performing operations in their individual capacity.

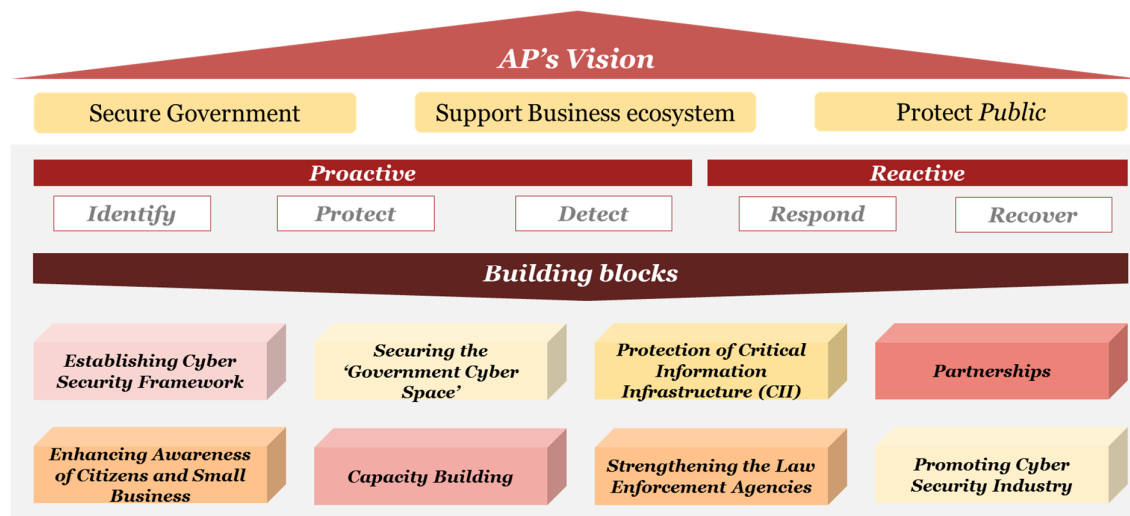


Figure 1. GoAP's Vision towards Cyber Security of the State

1.1. About the Document

Sustainable and effective cyber security implementation across the State requires a consistent approach to be followed by all the Government Departments. This document, AP Cyber Security Framework (AP-CSF), is designed to address and manage the cyber security risks in a comprehensive way. It will help in guiding all cyber security activities in the State, while balancing the need to protect individual privacy in a cost-effective manner. It needs to be adopted by all Government Departments, and private organizations, irrespective of size, degree of cyber security risk or sophistication of their operations. The document is intended to be a living document and will continue to be updated and improved as the technology landscape changes.

1.2. Purpose

AP-CSF will provide the organizations in the public and private sector, a structure to –

1. Assist in managing the confidentiality, integrity and availability of data and critical infrastructure
2. Manage and respond to evolving cyber risks across the value chain
3. Adopt a pragmatic yet flexible risk based approach
4. Be applicable across design, build/buy, deploy, operate and decommission life cycle phases
5. Leverage the international best practices, standards and guidelines.

1.3. Intended Audience

The intended audience includes (but is not limited to) Risk managers, Risk coordinators, Information security officers, Information security coordinators, IT managers, Technology Officers, Technology Operations team, Internal Audit and Compliance Officers.

1.4. Applicability

The framework is applicable to the entire community of public and private organizations, service providers and other supporting entities that play a role in securing Infrastructure of Andhra Pradesh.

2. Overview of AP – CSF

The AP – CSF has been designed by drawing from the “NIST Framework for Improving Critical Infrastructure Cyber Security” and “ISO 27001:2013”, and is in harmony with the Cyber Security Policy of the Government of Andhra Pradesh along with host of other industry standards and India specific regulations. The AP – CSF provides private and Government sector organizations with a structure for assessing and improving their ability to prepare for, prevent, detect, and respond to various cyber incidents.

The framework advocates business driven security controls across the Cyber Security Life Cycle i.e. **Identify, Protect, Detect, Respond and Recover**. These Functions are described below:

1. **Identify:** Includes inventorying the assets – physical and digital, identifying critical business functions, and assessing risks relating to the assets and business functions, and putting in place an appropriate risk management strategy and a governance mechanism for the same.
2. **Protect** – Includes creating systems for access control and data security, establishing Standard Operating Procedures, and deploying protective technologies.
3. **Detect** – Includes monitoring and analysis of anomalies and events.
4. **Respond** – Includes response planning, communications strategy, mitigation, and improvements for future resilience.
5. **Recover** – Includes recovery planning, enhancements to systems, and updates through immediate communications.

Selection of controls in the current version of AP-CSF has been done to facilitate monitoring of each control either through

- a. State Security Operations Centre (AP-CSOC) or
- b. Audits/Assessments

The structure of the cyber security framework for AP has been modeled after the Cyber Security Framework published by NIST, USA in 2013. NIST has released the updated CSF version 1.1 (Apr 2018). NIST prescribes three main components for the cyber security framework viz.

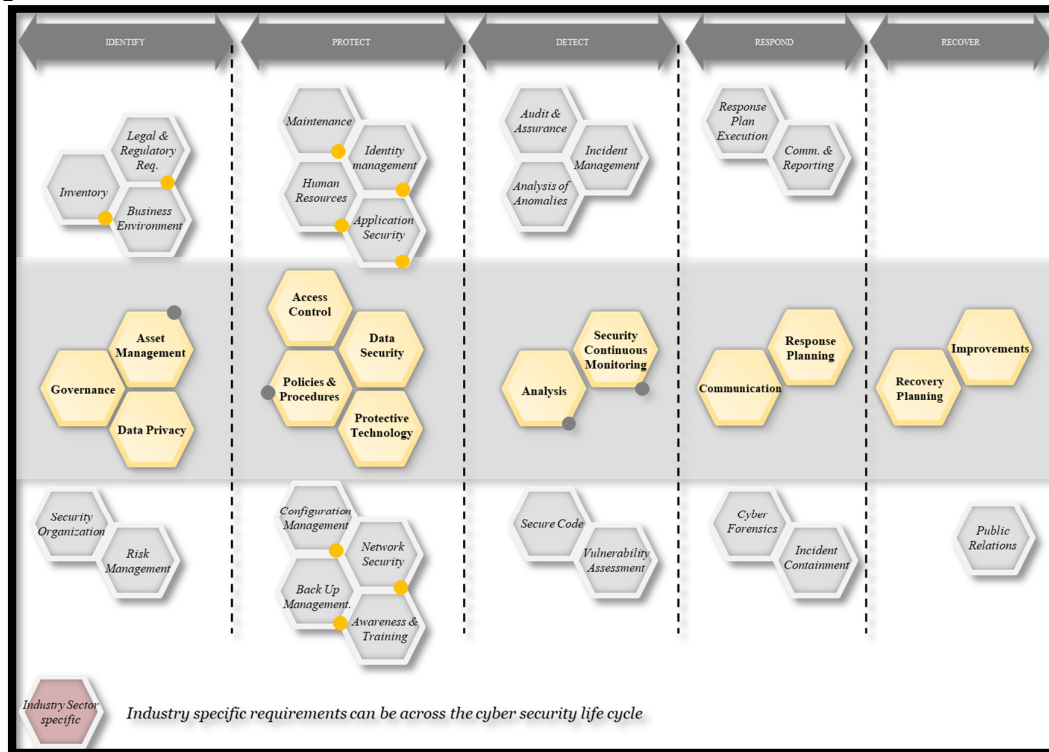
1. Core Framework
2. Framework Implementation Tiers
3. Framework Profile

The main components of AP-CSF are

1. Unified Control Matrix
2. Inherent Risk
3. Framework Profile and
4. Cyber Security Environment

Figure 2 depicts the spread of the control areas and sub –areas across the cyber security lifecycle into a baseline and an advanced framework. The layer depicted in the center along with the control areas in grey is the representation of the baseline Control areas, which can be enhanced with additional controls and industry context represented.

Figure 2. AP – CSF Overview



Legend:

	Baseline Controls
	Advanced Security Controls
	Industry Specific Requirements

2.1. AP CSF and AP Cyber Security Policy

AP Cyber Security Policy (G.O.MS.No.2,IT,E&C (Infra) Dept., Dated:01.03.2017) also mentions several other components which are not referred in this framework document directly; however, they have symbiotic relationship and should be seen in conjunction with this document for holistic cyber security coverage for the State. Table below lists the other components and their significance below:

Table 1: Relationship between AP CS Policy Components with AP CSF Control Functions

Component of AP CS Policy	Description	Related Function	Related Categories
AP CRT and AP-CSOC	An autonomous Body and Physical infrastructure with technical capabilities managed and operated by APTS	Detect, Protect	Security Continuous Monitoring, Analysis, Protective Technologies, Maintenance
Cyber Security Call Centre	Function with the AP Police to understand and react on the cybercrime complaints	Respond	Communication
Website (AP CRT)	Channel for information exchange on cyber security threats, impacts and suggested actions/guidelines	Identify, Detect, Protect and Respond	Awareness, Data Security, Continuous Monitoring and Communication
Digital Identities Strategy	Strategy for using digital identities for various Government schemes	Identify, Protect	Access Control, Protective Technologies
Capacity Building	Cyber Skill building and training programs	Protect	Awareness, Information Protection Process and Procedures

3. Components of AP – CSF

1. AP-CSF is aligned to NIST CSF in principle with modifications and comprises of four key components viz.
2. Unified Control Matrix
3. Inherent Risk
4. Framework Profile
5. Cyber security Environment

3.1. Unified Control Matrix

AP – CSF provides the Unified Control Matrix (UCM) equivalent to Core Component of NIST CSF. UCM has been created after studying several global best practices and standards for cyber security. Figure 3. List of Standards, Best Practices, and Regulatory Requirements mapped.

	Internet of Things (IoT)	OWASP IoT Frameworks, CSA (cloud security best practices), NIST (800-183; NISTIR 8114, 7628 etc.)
	SCADA Systems/ Operational Technologies/ Manufacturing Technologies	NIST 800-82, IEC 62443, NERC
	Web Applications	OWASP Top 10 web application securities, ISO 27034
	Mobile Applications	OWASP Top 10 mobile security risk
	Payment card and related information/ financial infrastructure	PCI-DSS
	Digital Entities	SANS CSC, NIST 800-63-3
Legal and Regulatory		International Best Practices
IT Act, Cert-IN, National Cyber Security Policy 2013, RBI, NCIIPC Guidelines, Aadhaar Act		ISO 27001, ISO 27002, ISO 27037, ISO 27043

Figure 3. List of Standards, Best Practices, and Regulatory Requirements mapped

UCM has been designed with 185 controls with more than nine international and national standards and regulatory requirements mapped to suit the needs of the State. Benefits of UCM are:

1. Reduces compliance cost for the departments with overlap of controls prescribed by different standards
2. Simplifies control selection and implementation

UCM contains (both proactive and reactive) controls across the three dimensions - people, process, and technology, and 16 security domains. For enabling a phased implementation by the Departments/organizations which are yet to embark on the journey of cyber security, the control matrix has been divided into two categories viz. **Baseline security controls** and **Advanced security controls**. These are listed in section 4 (Control Universe) of the document.

3.2. Inherent Risk

AP-CSF proposes risk-based identification of security controls. It is suggested that departments/organizations identify the inherent risk to business by following risk management standards such as ISO 31000 and ISO 27005. Inherent risk is created because of several factors which could arise from any of the following scenarios, a department managing critical infrastructure, and/or providing citizen services, and/or holding or dealing with sensitive government data or personal data.

A systematic assessment of inherent risk should guide the selection and strength of the advanced security controls to be deployed and must meet the specific requirements of the industry sector. Section 5 of the document can be referred to identify the domain-specific requirements.

3.3. Framework Profile

Framework profile enables organizations to:

1. Establish a roadmap for reducing cyber security risk that is well aligned to the organizational and sector goals,
2. Consider legal/ regulatory requirements and industry best practices, and
3. Reflect risk management priorities.

It identifies the current profile and target profile with respect to AP-CSF. The Current Profile indicates the cyber security posture as is. The Target Profile indicates the posture needed to achieve the desired cyber security risk management goals. A comparison of Profiles (e.g., the Current Profile and Target Profile) reveals the gaps to be addressed to meet the cyber security risk management objectives. An action plan to address these gaps can contribute to the smooth implementation of the roadmap described above. Prioritization of gap mitigation is driven by the organization's business needs and risk management processes.

3.4. Cyber Security Environment

Security is not the exclusive concern of the Government or a few organizations holding critical assets in the cyber space. It is a collective concern of all the actors in the society. Keeping this in view, AP-CSF recommends a holistic approach to take the security initiatives to a higher level by seeking active contribution for maturing the cyber security posture of the entire state by:

1. Participating in building state level threat intelligence with live feeds
2. Demonstrating responsible behavior by sharing information on security incidents
3. Undertaking capacity building initiatives in the cyber security domain
4. Promoting innovative cyber-security technologies
5. Fostering partnership with industry, academia and law enforcement agencies

4. Control Universe

The control universe of AP – CSF defines the most critical cyber security controls required to protect Government and private sector organizations. The control list relies on a wide range of existing standards, guidelines, and practices such as ISO 27001:2013, COBIT 5, NCIIPC Guidelines, UIDAI Regulations, RBI Cyber Security Guidelines, PCI DSS requirements, IRDAI's information and cyber security guidelines, and NIST 800-53, to enable critical infrastructure providers to achieve resilience. By relying on these Indian and Global standards, guidelines, and practices developed, managed, and updated by the AP industry, the tools and methods available to achieve the Framework outcomes; acknowledge the global nature of cyber security risks, and evolve with technological advances and business requirements.

For the ease of implementation and to bring the different departments and organizations to the minimum security standard the control universe has been divided into two sections defined below:

1. **Baseline Controls** – A set of 91 security controls which should be implemented as mandatory controls by all organizations. These controls are to be implemented irrespective of the scale and type of business or function carried out by the organization.
2. **Advanced Controls** – A set of 94 risk-based controls which should be implemented by organizations commensurate to the business risk and identified need for security

controls. The list of controls mentioned have to be implemented in addition to the baseline controls. Each organization should implement the relevant controls tailored to industry sector needs in addition to the risk posture of the organization and ensure that processes and people are in place to continuously manage the controls.

"IDENTIFY-4 to 9,20 & 22 to 25, PROTECT-28 to 37,40 to 43,65 to 83,92 to 95,97&103 to 126, DETECT-7 to 19, 22 & 23, RESPOND-4 to 7 and RECOVER-2)in the Control MatrixareAdvanced Controls".

Cyber Security Controls are implemented to address the threat environment and the operating infrastructure known at the time. As threat environments change, such as the shift to cloud, mobile, Internet of Things (IoT), Big Data, analytics, so must the controls change and existing controls be updated. The scope of security audit should also be accordingly widened to ensure coverage of the new risk dimensions.

4.1. Controls

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
IDENTIFY-1	Governance	BS.ID.GV 1	Organizational information security policy is established	An information security policy document should be approved by management, and published and communicated to all employees and relevant external parties.	NIST 800-53 Rev 4: All XX-1 controls, ISO 27001:2013 A.5, COBIT 4: PO6 DS5 ME2 COBIT 5: APO01.03 , NCIIPC Guidelines v2 (2015): PC 4
IDENTIFY-2	Governance	BS.ID.GV 2	Organizational information security policy is established	The information security policy should be reviewed at planned intervals or earlier, if significant changes occur ensure its continuing suitability, adequacy, and effectiveness.	NIST 800-53 Rev 4: All XX-1 controls, ISO 27001:2013 A.5, COBIT 4: PO3 PO5 PO6 PO9 DS5 ME2 ME4 COBIT 5: APO01.03 , NCIIPC Guidelines v2 (2015): PC 4
IDENTIFY-3	Governance	BS.ID.GV 3	Information security roles & responsibilities are coordinated and aligned with internal roles and external partners	Security roles and responsibilities of employees, contractors and third party users should be defined and documented in accordance with the department's information security policy.	NIST 800-53 Rev 4: CM-9, CP-2,PS-7, SA-3, SA-9, PM- 2, PM-10, ISO 27001:2013 A.6.1, COBIT 4: PO4 COBIT 5: APO01.02 , NCIIPC Guidelines v2 (2015): PC 4

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
IDENTIFY-4	Governance	AD.ID.GV 1	Information security roles & responsibilities are coordinated and aligned with internal roles and external partners	Representatives should be appointed to support and enhance security across different areas. At a minimum, the following should be positioned:	NIST 800-53 Rev 4: CM-9, CP-2, PS-7, SA-3, SA-9, PM- 2,
				1. Network Administrator: responsible to manage the networks of department, ensure network security, install new security applications, and distribute software upgrades.	PM-10, ISO 27001:2013 A.6.1, COBIT 4: PO4 COBIT 5: APO01.01 , NCIIPC Guidelines v2 (2015): PC 4
				2. System Administrator: responsible for the installation and maintenance of an information system including DBA, and sound implementation of established Information Assurance policy and procedures	
IDENTIFY-5	Governance	AD.ID.GV 2	Information security roles & responsibilities are coordinated and aligned with internal roles and external partners	Duties and areas of responsibility should be segregated to reduce opportunities for unauthorized or unintentional modification or misuse of the assets. To this end, 1. Information Security Officer role should be defined exclusively for IT operations. 2. System administrator	NIST 800-53 Rev 4: AC-5, ISO 27001:2013 A.6.1, COBIT 4: PO4 COBIT 5: APO01.02 , NCIIPC Guidelines v2 (2015): IC 2

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				should be segregated from application administrator. 3. The development, test and production environments need to be properly segregated.	
IDENTIFY-6	Governance	AD.ID.GV3	Information security roles & responsibilities are coordinated and aligned with internal roles and external partners	The expected network performance and security levels should be defined and included in service level agreements as part of the contract between department and network service provider	NIST 800-53 Rev 4: SA-4, SA-12, ISO 27001:2013 A.15, COBIT 4: DS1 DS2 COBIT 5: APO09.04 APO09.05, NCIIPC Guidelines v2 (2015): PC10
IDENTIFY-7	Governance	AD.ID.GV4	Legal and regulatory requirements regarding cybersecurity, including privacy and civil liberties obligations, are understood and managed	Information security office should maintain a list of certifications which are needed to be implemented for the protection of critical information infrastructure assets. The list should be reviewed periodically	NCIIPC Guidelines v2 (2015): PC 11
IDENTIFY-8	Governance	AD.ID.GV5	Legal and regulatory requirements regarding cybersecurity, including privacy and civil liberties obligations, are understood and managed	Audit requirements on the operational systems should be planned and documented and agreed in order to minimize the risk of disruptions to business processes	NIST 800-53 Rev 4: CA-2(1), SA-11(3), ISO 27001:2013 A.18, COBIT 4: PO4 ME3 COBIT 5: MEA03.03 MEA03.01, NCIIPC Guidelines v2 (2015): RA3
IDENTIFY-9	Governance	AD.ID.GV6	Legal and regulatory requirements regarding	Periodic (annual) information security and privacy audit by an	NIST 800-53 Rev 4: CA-2(1), SA-11(3), ISO 27001:2013 A.18, COBIT 4: PO4

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
			cybersecurity , including privacy and civil liberties obligations, are understood and managed	independent third party should be conducted to ensure compliance to the information security policy and Regulatory requirements.	ME3 COBIT 5: MEA03.03 MEA03.01, NCIIPC Guidelines v2 (2015): RA3
IDENTIFY-10	Data Privacy	BS.ID.DP 1	Legal and regulatory requirements regarding cybersecurity , including privacy and civil liberties obligations, are understood and managed	Collection of personal data shall be limited to such data that is necessary for the purposes of processing.	ISO 27001:2013 A.18, COBIT 4: PO4 ME3 COBIT 5: MEA03.03 MEA03.01
IDENTIFY-11	Data Privacy	BS.ID.DP 2	Legal and regulatory requirements regarding cybersecurity , including privacy and civil liberties obligations, are understood and managed	Personal data should be processed only for purposes specified, having regard to the specified purposes, and the context and circumstances in which the personal data was collected	ISO 27001:2013 A.18, COBIT 4: PO4 ME3 COBIT 5: MEA03.03 MEA03.01
IDENTIFY-12	Data Privacy	BS.ID.DP 3	Legal and regulatory requirements regarding cybersecurity , including privacy and civil liberties obligations, are understood and managed	Department should take reasonable steps to ensure that personal data processed is complete, accurate, not misleading and updated, having regard to the purposes for which it is processed	ISO 27001:2013 A.18, COBIT 4: PO4 ME3 COBIT 5: MEA03.03 MEA03.01,
IDENTIFY-13	Data Privacy	BS.ID.DP 4	Legal and regulatory requirements regarding cybersecurity , including privacy and civil liberties	Departments should ensure that 1. technology used in the processing of personal data is in accordance	ISO 27001:2013 A.18, COBIT 4: PO4 ME3 COBIT 5: MEA03.03 MEA03.01,

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
			obligations, are understood and managed	with commercially accepted or certified standards 2. privacy is protected throughout processing from the point of collection to deletion of personal data 3. processing of personal data is carried out in a transparent manner; and 4. the interest of the citizen is protected at every stage of processing of personal data	
IDENTIFY-14	Data Privacy	BS.ID.DP 5	Legal and regulatory requirements regarding cybersecurity , including privacy and civil liberties obligations, are understood and managed	The identity information, other than core biometric information, collected or created under AADHAAR Act may be shared only in accordance with the provisions of the Act and in such manner as may be specified by AADHAAR regulations.	Section 29(2) of AADHAAR ACT 2016
IDENTIFY-15	Data Privacy	BS.ID.DP 6	Legal and regulatory requirements regarding cybersecurity , including privacy and civil liberties obligations, are understood and managed	Citizen identity information (e.g., Aadhaar number, demographic and biometric information) should be captured after appropriate consent from the respective citizen. It should be ensured that the citizen information (e.g., Aadhaar	NIST 800-53 Rev 4: Appendix J Privacy controls, ISO 27001:2013 A.18, COBIT 4: PO4 ME3 COBIT 5: MEA03.03 MEA03.01,

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				number, demographic and biometric information) is not published on Department website.	
IDENTIFY-16	Asset Management	BS.ID.AM 1	Physical devices and systems within the organization are inventoried	An asset register should be maintained to capture all the IT assets and should be reviewed, at least, annually.	NIST 800-53 Rev 4: CM-8, ISO 27001:2013 A.8, COBIT 4: PO2 DS9 COBIT 5: BAI09 , NCIIPC Guidelines v2 (2015): IC 1
IDENTIFY-17	Asset Management	BS.ID.AM 2	Physical devices and systems within the organization are inventoried	The assets should be labeled and secured based on the Information Asset classification guidelines into top secret, secret, confidential, restricted or unclassified, from the time it is created until the time it is destroyed or disposed.	NIST 800-53 Rev 4: CM-8, ISO 27001:2013 A.8, COBIT 4: PO2 DS9 COBIT 5: BAI09 , NCIIPC Guidelines v2 (2015): IC 1
IDENTIFY-18	Asset Management	BS.ID.AM 3	Physical devices and systems within the organization are inventoried	Owners responsible for each IT asset should be identified.	NIST 800-53 Rev 4: CM-8, ISO 27001:2013 A.8, COBIT 4: PO2 DS9 COBIT 5: BAI09 , NCIIPC Guidelines v2 (2015): IC 1
IDENTIFY-19	Asset Management	BS.ID.AM 4	Physical devices and systems within the organization are inventoried	All the assets issued by Department should be returned by the user on termination or change of employment (e.g., transfer to other Department).	NIST 800-53 Rev 4: PS-4, PS-5, ISO 27001:2013 A.8, COBIT 4: PO2 DS9 COBIT 5: BAI09 , NCIIPC Guidelines v2 (2015): IC 1
IDENTIFY-20	Asset Management	AD.ID.AM 1	Physical devices and systems within the organization are inventoried	Asset tracking mechanism for mobile devices should be maintained.	NIST 800-53 Rev 4: CM-8, ISO 27001:2013 A.8, COBIT 4: PO2 DS9 COBIT 5: BAI09 , NCIIPC Guidelines v2 (2015): IC 1

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
IDENTIFY-21	Business Environment	BS.ID.BE 1	Resilience requirements to support delivery of critical services are established	Single point of failures should be identified and controls should be in place to address them.	NIST 800-53 Rev 4: CP-6, CP-7, CP-8, CP-9, CP-10, CP-11, CP-13, ISO 27001:2013 A.17, COBIT 4: PO3 PO9 DS4 DS8 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): DR 1 DR 2 DR 3
IDENTIFY-22	Business Environment	AD.ID.BE 1	Resilience requirements to support delivery of critical services are established	Risk assessment and business impact analysis should be conducted periodically, duly identifying and considering the threats to the business environment and the vulnerabilities of the existing IT Systems. A standard methodology be adopted for risk assessment.	ISO 27005, ISO 31000, NIST 800-53 Rev 4: CP-6, CP-7, CP-8, CP-9, CP-10, CP-11, CP-13, ISO 27001:2013 A.17, COBIT 4: PO3 PO9 DS4 DS8 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): DR 1 DR 2 DR 3
IDENTIFY-23	Business Environment	AD.ID.BE 2	Resilience requirements to support delivery of critical services are established	Disaster recovery site selection policy, procedures and implementation should be formalized.	NCIIPC Guidelines v2 (2015): DR 1 DR 2 DR 3
IDENTIFY-24	Business Environment	AD.ID.BE 3	Resilience requirements to support delivery of critical services are established	Review, audit and feedback of the disaster recovery site should be performed to ensure smooth operations of the same at the time of disaster.	NCIIPC Guidelines v2 (2015): DR 1 DR 2 DR 3
IDENTIFY-25	Business Environment	AD.ID.BE 4	Resilience requirements to support delivery of critical services are established	Data back-up plan should be implemented at the DR site which is critical for normalizing the	NCIIPC Guidelines v2 (2015): OC 4

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				operations in the event of disaster.	
PROTEC T-1	Information Protection Processes and Procedures	BS.PR.IP 1	Cybersecurity is included in human resources practices (e.g., de-provisioning, personnel screening)	Partner support personnel should provide the information regarding the background such as education, criminal record, employment history etc. and provide a self-declaration that the information provided is correct. This information should be validated during or after the employment of the respective personnel.	NIST 800-53 Rev 4: PS-3, SA-21, ISO 27001:2013 A.7, COBIT 4: PO4 PO6 PO7 COBIT 5: APO07.01 APO07.02, NCIIPC Guidelines v2 (2015): PC 12
PROTEC T-2	Information Protection Processes and Procedures	BS.PR.IP 2	Cybersecurity is included in human resources practices (e.g., de-provisioning, personnel screening)	All employees should sign a confidentiality (non-disclosure) agreement. This could be done through a self-declaration document.	NIST 800-53 Rev 4: PL-4, PS-6, ISO 27001:2013 A.7, COBIT 4: PO4 PO6 PO7 COBIT 5: APO07.06 , NCIIPC Guidelines v2 (2015): PC 12
PROTEC T-3	Information Protection Processes and Procedures	BS.PR.IP 3	Cybersecurity is included in human resources practices (e.g., de-provisioning, personnel screening)	All employees handling department information assets should adhere to the following information security requirements: a) Complete all on-boarding and recurring information security awareness trainings provided by department. b) Be aware of the department disciplinary process in the event of an	NIST 800-53 Rev 4: PL-4, PS-6, ISO 27001:2013 A.7, COBIT 4: PO4 PO6 PO7 COBIT 5: APO07.01 , NCIIPC Guidelines v2 (2015): OC3

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				information security breach.	
PROTEC T-4	Information Protection Processes and Procedures	BS.PR.IP 4	Cybersecurity is included in human resources practices (e.g., de-provisioning, personnel screening)	Access rights of terminated or transferred employees should be revoked simultaneously with the termination or transfer or within 24 hours of the same.	NIST 800-53 Rev 4: AT-2, AT-3, CP-3, IR-2, PM-13, ISO 27001:2013 A.7, COBIT 4: PO4 PO6 PO7 COBIT 5: APO07.01 , NCIIPC Guidelines v2 (2015): OC 3
PROTEC T-5	Information Protection Processes and Procedures	BS.PR.IP 5	Cybersecurity is included in human resources practices (e.g., de-provisioning, personnel screening)	Procedures should be created to change the roles of the associates in a function/team (or) and to allow exchange of people between the teams.	NIST 800-53 Rev 4: AT-2, AT-3, CP-3, IR-2, PM-13, ISO 27001:2013 A.7, COBIT 4: PO4 PO6 PO7 COBIT 5: APO07.01 , NCIIPC Guidelines v2 (2015): OC 3
PROTEC T-6	Information Protection Processes and Procedures	BS.PR.IP 6	Policy and regulations regarding the physical operating environment for organizational assets are met	Power and telecommunication s cable, carrying data or supporting information services, should be protected from interception or damage by installing them underground or using optical cable fiber for critical information transmission	NIST 800-53 Rev 4: CP-8, PE-9, PE-10, PE-11, PE-12, PE-14, PE-15, ISO 27001:2013 A.11, COBIT 4: DS12 COBIT 5: DSS05.05 DSS01.04, NCIIPC Guidelines v2 (2015): PC12
PROTEC T-7	Information Protection Processes and Procedures	BS.PR.IP 7	Configuration change control processes are in place	A Standard Operating Procedure (SOP) should be developed for all information systems and services to ensure uniformity of operations. The SOP should include but not be limited to the following: 1) Day-to-day operational tasks	NIST 800-53 Rev 4: All XX-1 controls, SA-5, ISO 27001:2013 A.12, COBIT 4: AI1 AI4 DS13 COBIT 5: BAI02.01 , NCIIPC Guidelines v2 (2015): IC 4

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				that need to be performed including exception handling. 2) Operational activities and maintenance of the system or service and the actions to be taken in the event of a failure. 3) Activities like starting, restart or shutdown of a specific system or application. 4) Any maintenance agreements with the details of the contact names, commencement and termination dates of agreements.	
PROTEC T-8	Information Protection Processes and Procedures	BS.PR.IP 8	Configuration change control processes are in place	Authorized configuration manager should be identified for ensuring version control of all software installed on systems.	NIST 800-53 Rev 4: CM-3, CM-5, SA-10, ISO 27001:2013 A.12, COBIT 4: AI1 AI4 DS13 COBIT 5: BAI02.01 , NCIIPC Guidelines v2 (2015): IC 4
PROTEC T-9	Information Protection Processes and Procedures	BS.PR.IP 9	Configuration change control processes are in place	Any changes to the information processing facilities and systems should be first approved by appropriate authority and logged. These changes can be: 1. Configuration changes 2. Change of OS 3. Use of new technology	NIST 800-53 Rev 4: CM-3, CM-5, SA-10, ISO 27001:2013 A.12, COBIT 4: AI6 COBIT 5: BAI06 , NCIIPC Guidelines v2 (2015): IC 4
PROTEC T-10	Information Protection Processes and Procedures	BS.PR.IP 11	Backups of information are conducted, maintained,	All applications, operating system software and data that need to be backed up should	NIST 800-53 Rev 4: CP-9, ISO 27001:2013 A.12, COBIT 4: DS13 COBIT 5: DSS01.01

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
			and tested periodically	be identified and documented, duly specifying the frequency, medium of and storage of the backup.	DSS01.03, NCIIPC Guidelines v2 (2015): OC 4
PROTEC T-11	Information Protection Processes and Procedures	BS.PR.IP 12	Backups of information are conducted, maintained, and tested periodically	Backup records should be maintained and be updated regularly to keep track of the data that has been backed up.	NIST 800-53 Rev 4: CP-9, ISO 27001:2013 A.12, COBIT 4: DS4 DS11 COBIT 5: DSS04 , NCIIPC Guidelines v2 (2015): OC 4
PROTEC T-12	Information Protection Processes and Procedures	BS.PR.IP 13	Configuration change control processes are in place	System clocks of all information processing system should be synchronized with an agreed accurate time source.	NIST 800-53 Rev 4: AU-8, ISO 27001:2013 A.12, COBIT 4: DS13 COBIT 5: DSS04 , NCIIPC Guidelines v2 (2015): OC 4
PROTEC T-13	Information Protection Processes and Procedures	BS.PR.IP 14	A vulnerability management plan is developed and implemented	Vulnerability assessments including penetration testing and application security testing should be performed on a quarterly basis.	NIST 800-53 Rev 4: RA-3, RA-5, SI-2, SI-5, ISO 27001:2013 A.12, COBIT 4: AI3 AI6 DS5 DS9 COBIT 5: DSS04 , NCIIPC Guidelines v2 (2015): OC5
PROTEC T-14	Information Protection Processes and Procedures	BS.PR.IP 15	A vulnerability management plan is developed and implemented	Time lines should be defined for taking preventive actions on vulnerability notifications based on the risk and relevant technical notifications.	NIST 800-53 Rev 4: RA-3, RA-5, SI-2, SI-5, ISO 27001:2013 A.12, COBIT 4: AI3 AI6 DS5 DS9 COBIT 5: DSS04 , NCIIPC Guidelines v2 (2015): OC5
PROTEC T-15	Information Protection Processes and Procedures	BS.PR.IP 16	A System Development Life Cycle to manage systems is implemented	All software development personnel should receive training in writing secure code for their specific development environment.	NIST 800-53 Rev 4: SA-3, SA-15, SA-17, ISO 27001:2013 A.14, COBIT 4: AI1 AI2 AI3 COBIT 5: BAI03 , NCIIPC Guidelines v2 (2015): IC 4
PROTEC T-16	Information Protection Processes and Procedures	BS.PR.IP 17	A System Development Life Cycle to manage	All additions and changes during the entire system development lifecycle should be	NIST 800-53 Rev 4: SA-3, SA-15, SA-17, ISO 27001:2013 A.14, COBIT 4: AI2 AI6 AI7 COBIT

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
			systems is implemented	verified and authorized	5: BAI03 , NCIIPC Guidelines v2 (2015): IC 4
PROTEC T-17	Information Protection Processes and Procedures	BS.PR.IP 18	A System Development Life Cycle to manage systems is implemented	Rules for the development of software and systems should be established and applied to developments. Rules at minimum should include: 1. Developments should undergo adequate testing before they are deployed. 2. Repositories of source code should be appropriately secured.	NIST 800-53 Rev 4: SA-3, SA-15, SA-17, ISO 27001:2013 A.14, COBIT 4: AI1 AI2 AI3 COBIT 5: BAI03 , NCIIPC Guidelines v2 (2015): IC 4
PROTEC T-18	Information Protection Processes and Procedures	BS.PR.IP 19	A System Development Life Cycle to manage systems is implemented	Secure code reviews and penetration testing of the applications should be performed.	NIST 800-53 Rev 4: SA-3, SA-15, SA-17, ISO 27001:2013 A.14, COBIT 4: AI1 AI2 AI3 COBIT 5: BAI03 , NCIIPC Guidelines v2 (2015): IC 4
PROTEC T-19	Information Protection Processes and Procedures	BS.PR.IP 20	A System Development Life Cycle to manage systems is implemented	The ownership of source code should be maintained.	NIST 800-53 Rev 4: SA-3, SA-15, SA-17, ISO 27001:2013 A.14, COBIT 4: AI1 AI2 AI3 COBIT 5: BAI03 , NCIIPC Guidelines v2 (2015): IC 4
PROTEC T-20	Information Protection Processes and Procedures	BS.PR.IP 21	Protection processes are continuously improved	New technology developed should be analyzed for security risks and the design should be reviewed against known attack patterns.	NIST 800-53 Rev 4: CA-2, SA-11, ISO 27001:2013 A.14, COBIT 4: AI1 AI2 AI3 COBIT 5: BAI03 , NCIIPC Guidelines v2 (2015): IC 6
PROTEC T-21	Information Protection Processes and Procedures	BS.PR.IP 22	A System Development Life Cycle to manage systems is implemented	Sample scripts, libraries or any other unnecessary code that is not being used by an application should be uninstalled or	NIST 800-53 Rev 4: SA-8, ISO 27001:2013 A.14, COBIT 4: AI1 AI2 AI3 COBIT 5: BAI03 , NCIIPC

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				removed from the system.	Guidelines v2 (2015): IC 4
PROTEC T-22	Information Protection Processes and Procedures	BS.PR.IP 23	A System Development Life Cycle to manage systems is implemented	Development artifacts (e.g., sample data and scripts; unused libraries, debug code) should not be included in the deployed software, or accessible in the production environment.	NIST 800-53 Rev 4: SA-8, ISO 27001:2013 A.14, COBIT 4: AI1 AI2 AI3 COBIT 5: BAI03 , NCIIPC Guidelines v2 (2015): IC 4
PROTEC T-23	Information Protection Processes and Procedures	BS.PR.IP 24	Response plans (Incident Response and Business Continuity) and recovery plans (Incident Recovery and Disaster Recovery) are in place and managed	Incident Management Process should be defined to handle and resolve all types of information security incidents and recover from security breaches.	NIST 800-53 Rev 4: IR-8, ISO 27001:2013 A.16, COBIT 4: PO6 DS5 DS8 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): OC2
PROTEC T-24	Information Protection Processes and Procedures	BS.PR.IP 25	Response plans (Incident Response and Business Continuity) and recovery plans (Incident Recovery and Disaster Recovery) are in place and managed	Roles and responsibilities should be assigned for handling incidents and for supporting the incident handling process making decisions.	NIST 800-53 Rev 4: IR-8, ISO 27001:2013 A.16, COBIT 4: PO6 DS5 DS8 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): OC2
PROTEC T-25	Information Protection Processes and Procedures	BS.PR.IP 26	Response plans (Incident Response and Business Continuity) and recovery plans (Incident Recovery and Disaster	Business Continuity Plan should be developed to maintain and restore business operations, ensure availability of information within the required level in the required time	NIST 800-53 Rev 4: CP-2, ISO 27001:2013 A.17, COBIT 4: PO3 PO9 DS4 DS8 COBIT 5: BAI06 , NCIIPC Guidelines v2 (2015): DR 1 DR 2 DR 3

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
			Recovery) are in place and managed	frame following an interruption or failure to business processes	
PROTEC T-26	Information Protection Processes and Procedures	BS.PR.IP 27	Response and recovery plans are tested	Business continuity plan should be tested regularly to ensure that they are up to date and effective.	NIST 800-53 Rev 4: CP-4, ISO 27001:2013 A.17, COBIT 4: PO3 PO9 DS4 DS8 COBIT 5: BAI06 , NCIIPC Guidelines v2 (2015): DR 1 DR 2 DR 3
PROTEC T-27	Information Protection Processes and Procedures	BS.PR.IP 28	Cybersecurity is included in human resources practices (e.g., deprovisioning, personnel screening)	Awareness and training programs should be held periodically (monthly, quarterly or annually) for employees, third parties and contractors to create awareness in context of information security.	NIST 800-53 Rev 4: AT-2, AT-3, CP-3, IR-2, PM-13, ISO 27001:2013 A.7, COBIT 4: PO4 PO6 PO7 COBIT 5: APO07.01 , NCIIPC Guidelines v2 (2015): OC 3
PROTEC T-28	Information Protection Processes and Procedures	AD.PR.IP 1	Cybersecurity is included in human resources practices (e.g., deprovisioning, personnel screening)	A bounty programme should be initiated among citizens to report gaps and vulnerabilities in government systems.	NIST 800-53 Rev 4: AT-2, AT-3, CP-3, IR-2, PM-13, ISO 27001:2013 A.7, COBIT 4: PO4 PO6 PO7 COBIT 5: APO07.01 , NCIIPC Guidelines v2 (2015): OC 3
PROTEC T-29	Information Protection Processes and Procedures	AD.PR.IP 2	Policy and regulations regarding the physical operating environment for organizational assets are met	Utility equipment should be located in physically segregated area, and the access is restricted to authorized personnel only. The monitoring and maintenance of utility equipment should be conducted on a regular basis.	NIST 800-53 Rev 4: CP-8, PE-9, PE-10, PE-11, PE-12, PE-14, PE-15, ISO 27001:2013 A.11, COBIT 4: DS12 COBIT 5: DSS05.05 DSS01.04, NCIIPC Guidelines v2 (2015): PC12
PROTEC T-30	Information Protection Processes	AD.PR.IP 3	Configuration change control	Change Advisory Board (CAB) should be	NIST 800-53 Rev 4: CM-3, CM-5, SA-10, ISO 27001:2013

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
	and Procedures		processes are in place	established to review, manage and provide approval to implement changes. Once the change is successfully implemented, the request should be closed by the Change Approver.	A.12, COBIT 4: AI6 COBIT 5: BAI06 , NCIIPC Guidelines v2 (2015): IC 4
PROTEC T-31	Information Protection Processes and Procedures	AD.PR.IP 4	Protection processes are continuously improved	Web applications should be protected by deploying web application firewalls.	NIST 800-53 Rev 4: CA-2, SA-11, ISO 27001:2013 A.14, COBIT 4: AI1 AI2 AI3 COBIT 5: BAI03 , NCIIPC Guidelines v2 (2015): IC 4
PROTEC T-32	Information Protection Processes and Procedures	AD.PR.IP 5	Vulnerability scans are performed	All system devices should have update capability and be updated quickly when vulnerabilities are discovered. Update files should be encrypted and transmitted using encryption. Update files should be signed and validated before installing.	IoT Security Guidance by OWASP: I9
PROTEC T-33	Information Protection Processes and Procedures	AD.PR.IP 6	Vulnerability scans are performed	Cloud-based web interfaces should be tested for XSS, SQLi and CSRF vulnerabilities at minimum	IoT Security Guidance by OWASP: I6
PROTEC T-34	Information Protection Processes and Procedures	AD.PR.IP 7	Vulnerability scans are performed	Web interfaces in the IoT solution should be tested for XSS, SQLi and CSRF vulnerabilities	NCIIPC Guidelines v1 (2013) Control 25 , IoT Security Guidance by OWASP: I1
PROTEC T-35	Information Protection Processes and Procedures	AD.PR.IP 8	Protection processes are continuously improved	Identify classified data to be protected.	NCIIPC Guidelines v2 (2015): OC 1

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
PROTEC T-36	Information Protection Processes and Procedures	AD.PR.IP 9	Protection processes are continuously improved	Any detection of APT attack should be immediately reported (with minimum time delay) to appropriate authority. The reporting should include date and time of attack and its detection, methodology used and the system and information accessed along with the potential impact.	NCIIPC Guidelines v1 (2013) Control 35
PROTEC T-37	Information Protection Processes and Procedures	AD.PR.IP 10	Protection processes are continuously improved	For protecting the CII against environmental threats, adequate climate & precision controls and protection against the negative effects of static electricity should be deployed.	NCIIPC Guidelines v1 (2013) Control 12
PROTEC T-38	Awareness and Training	BS.PR.AT 1	All users are informed and trained	Assigned acknowledgment should be received from employees, third parties and contractors , indicating that they have read, understand, and agree to abide by the acceptable use policy, before authorizing access to information and the information system.	NIST 800-53 Rev 4: PL-4, ISO 27001:2013 A.8, COBIT 4: PO4 PO6 COBIT 5: DSS06.06 , NCIIPC Guidelines v2 (2015): IC 1
PROTEC T-39	Awareness and Training	BS.PR.AT 2	All users are informed and trained	Instructions for acceptable use of assets should be enforced. These may at minimum include following (but not limited to):	NIST 800-53 Rev 4: PL-4, ISO 27001:2013 A.8, COBIT 4: PO2 DS9 COBIT 5: BAI09 , NCIIPC Guidelines v2 (2015): IC 1

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				1. User should keep passwords secure and do not share account or password information with anyone, including other personnel, family, or friends 2. Laptops left at department premises overnight should be placed in a locked drawer or cabinet at all times 3. User should be prohibited from sending spam via e-mail, text messages, pages, instant messages, voice mail, or other forms of electronic communication	
PROTEC T-40	Awareness and Training	AD.PR.AT 1	All users are informed and trained	Training material should be reviewed and updated on a periodic basis (monthly, quarterly and annually) based on the feedback received.	NIST 800-53 Rev 4: AT-2, AT-3, CP-3, IR-2, PM-13, ISO 27001:2013 A.7, COBIT 4: PO4 PO6 PO7 COBIT 5: APO07.01 , NCIIPC Guidelines v2 (2015): OC 3
PROTEC T-41	Awareness and Training	AD.PR.AT 2	All users are informed and trained	Periodic tests should be conducted for employees, third parties and contractors to evaluate effectiveness of the training.	NIST 800-53 Rev 4: AT-2, AT-3, CP-3, IR-2, PM-13, ISO 27001:2013 A.7, COBIT 4: PO4 PO6 PO7 COBIT 5: APO07.01 , NCIIPC Guidelines v2 (2015): OC 3

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
PROTEC T-42	Awareness and Training	AD.PR.AT 3	All users are informed and trained	Acceptable use policy should be reviewed and updated on an annual basis.	NIST 800-53 Rev 4: PL-4, ISO 27001:2013 A.8, COBIT 4: PO4 PO6 COBIT 5: DSS06.06 , NCIIPC Guidelines v2 (2015): IC 1
PROTEC T-43	Awareness and Training	AD.PR.AT 4	Third-party stakeholders (e.g., suppliers, customers, partners) understand roles & responsibilities	Security awareness training should be provided for supplier staff that handle or interact with information assets.	NIST 800-53 Rev 4: SA-12, ISO 27001:2013 A.15, COBIT 4: DS1 DS2 COBIT 5: APO09.04 APO09.05, NCIIPC Guidelines v2 (2015): PC10
PROTEC T-44	Access Control	BS.PR.AC 1	Identities and credentials are managed for authorized devices and users	All user account creation (for servers, network devices, desktops, laptops, etc.) should be subject to a provisioning and approval process.	NIST 800-53 Rev 4: AC-2, IA-2, IA-4, IA-5, IA-8, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1
PROTEC T-45	Access Control	BS.PR.AC 2	Identities and credentials are managed for authorized devices and users	Users should be provided with the least privilege access i.e. reasonable minimum rights and permissions to access systems, services and information that they need to fulfil their work-related activities according to their job role. Administrative privileges should be restricted for the following functions: 1. Execution of software that has the ability to make significant and security relevant changes to the operating system	NIST 800-53 Rev 4: AC-2, AC-3, AC-6, CM-5, IA-2, IA-4, IA-5, IA-8, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				2. Changes to the operating system for some or all users 3. Creation of new accounts and allocation of their privileges	
PROTEC T-46	Access Control	BS.PR.AC 3	Identities and credentials are managed for authorized devices and users	Each user should authenticate using a unique username and strong password to access applications, computers and network devices.	NIST 800-53 Rev 4: AC-2, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1
PROTEC T-47	Access Control	BS.PR.AC 4	Identities and credentials are managed for authorized devices and users	Use of generic user accounts should be prohibited. Generic user accounts should be used only in case of business needs and after approval of appropriate authority.	NIST 800-53 Rev 4: AC-2, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1
PROTEC T-48	Access Control	BS.PR.AC 5	Identities and credentials are managed for authorized devices and users	All users should be made aware of the policy regarding acceptable account usage and their personal responsibility to adhere to security policies.	NIST 800-53 Rev 4: AC-2, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1
PROTEC T-49	Access Control	BS.PR.AC 6	Identities and credentials are managed for authorized devices and users	Temporary accounts or Guest accounts, provided for temporary staff or for testing, should be removed or suspended when no longer required.	NIST 800-53 Rev 4: AC-2, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1
PROTEC T-50	Access Control	BS.PR.AC 7	Identities and credentials are managed for authorized devices and users	All user accounts should be reviewed and any account that cannot be associated with a business process and owner should be disabled. An account should be	NIST 800-53 Rev 4: AC-2, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				deleted if it is dormant for more than 30 days.	
PROTEC T-51	Access Control	BS.PR.AC 8	Identities and credentials are managed for authorized devices and users	An account should be deleted, as part of exit formalities, in case an employee leaves the organization.	NIST 800-53 Rev 4: AC-2, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1
PROTEC T-52	Access Control	BS.PR.AC 9	Access permissions are managed, incorporating the principles of least privilege and separation of duties	A formal process should be in place to provide administrative level access to systems or devices.	NIST 800-53 Rev 4: AC-2, AC-3, AC-6, CM-5, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1
PROTEC T-53	Access Control	BS,PR.AC 10	Access permissions are managed, incorporating the principles of least privilege and separation of duties	The ongoing need of a user to use highly privileged accounts should be reviewed regularly and special privileges should be removed or disabled when no longer required (e.g. when an individual changes role or leaves the organization or completes the designated task for which special privileges were required) or after a pre-defined period of inactivity (e.g. 3 months).	NIST 800-53 Rev 4: AC-2, AC-3, AC-6, CM-5, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1
PROTEC T-54	Access Control	BS.PR.AC 11	Identities and credentials are managed for authorized devices and users	Department should ensure that the password policy is implemented on all systems (e.g., servers, network devices, desktops, laptops, etc.)	NIST 800-53 Rev 4: A-5, ISO 27001:2013 A.9.4.3, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): IC 3 IC4

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				covering at least the following: 1. Minimum Length 8 character and 10 character for critical accounts 2. At least one special character and at least one numeric 3 User should not reuse last three passwords	
PROTEC T-55	Access Control	BS.PR.AC 12	Identities and credentials are managed for authorized devices and users	Password expiry should be configured to ensure that password is required to be changed after every 30 days.	NIST 800-53 Rev 4: A-5, ISO 27001:2013 A.9.4.3, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): IC 3 IC4
PROTEC T-56	Access Control	BS.PR.AC 13	Identities and credentials are managed for authorized devices and users	The responsibilities of user regarding the use of password should be circulated along the following: 1. Keep user Id and corresponding password confidential and refrain from sharing them with anyone 2. Change passwords whenever system or password is compromised	NIST 800-53 Rev 4: A-5, ISO 27001:2013 A.9.4.3, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): IC 3 IC4
PROTEC T-57	Access Control	BS.PR.AC 14	Physical access to assets is managed and protected	All employees should be issued with an identification card, with photograph. This should be worn visibly at all times within the department's premise. Reception areas should be manned by either a receptionist and by	NIST 800-53 Rev 4: PE-2, PE-3, PE-4, PE-5, ISO 27001:2013 A.11, COBIT 4: DS12 COBIT 5: DSS05.05 DSS01.04, NCIIPC Guidelines v2 (2015): PC12

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				security guard if required.	
PROTEC T-58	Access Control	BS.PR.AC 15	Physical access to assets is managed and protected	Visitors should be escorted by authorized personnel to enter the department's premise areas and visitor entry logs should be maintained.	NIST 800-53 Rev 4: PE-2, PE-3, PE-4, PE-5, ISO 27001:2013 A.11, COBIT 4: DS12 COBIT 5: DSS05.05 DSS01.04, NCIIPC Guidelines v2 (2015): PC12
PROTEC T-59	Access Control	BS.PR.AC 16	Physical access to assets is managed and protected	There should be CCTV surveillance camera installed in the premises.	NIST 800-53 Rev 4: PE-2, PE-3, PE-4, PE-5, ISO 27001:2013 A.11, COBIT 4: DS12 COBIT 5: DSS05.05 DSS01.04, NCIIPC Guidelines v2 (2015): PC12
PROTEC T-60	Access Control	BS.PR.AC 17	Physical access to assets is managed and protected	All visitors carrying Information Processing Equipment(such as Laptops, Palmtops, Personal Digital Assistant) or Media (such as CDs, Tapes, DATs) should be asked to declare such assets and the same should be recorded in a register at the security gate.	NIST 800-53 Rev 4: PE-2, PE-3, PE-4, PE-5, ISO 27001:2013 A.11, COBIT 4: DS12 COBIT 5: DSS05.05 DSS01.04, NCIIPC Guidelines v2 (2015): PC12
PROTEC T-61	Access Control	BS.PR.AC 18	Physical access to assets is managed and protected	All critical areas should be appropriately protected. This should include, but not limited to: 1. Access to information processing centers should be restricted only to staff who are authorized to have access to those areas. Access should be controlled through	NIST 800-53 Rev 4: PE-2, PE-3, PE-4, PE-5, ISO 27001:2013 A.11, COBIT 4: DS12 COBIT 5: DSS05.05 DSS01.04, NCIIPC Guidelines v2 (2015): PC12

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				appropriate access control and authentication mechanisms e.g. biometric, access card. 2. Lockable cabinets or safes should be provided in the offices, rooms and other information processing facilities for critical information storage. 3. Photocopiers and fax machines should not be located within secure areas. 4. All hub rooms containing devices such as routers, network switches and other network devices should be secured using biometric or access card.	
PROTEC T-62	Access Control	BS.PR.AC 19	Physical access to assets is managed and protected	Physical protection measures should be deployed. This should include, but not limited to: 1. Fire extinguishing systems should be deployed. 2. Hazardous or combustible materials should be housed away from information processing facilities.	NIST 800-53 Rev 4: PE-2, PE-3, PE-4, PE-5, ISO 27001:2013 A.11, COBIT 4: DS12 COBIT 5: DSS05.05 DSS01.04, NCIIPC Guidelines v2 (2015): PC12
PROTEC T-63	Access Control	BS.PR.AC 20	Physical access to assets is managed and protected	The security requirements for protecting unattended equipment should be communicated	NIST 800-53 Rev 4: AC-11, ISO 27001:2013 A.11, COBIT 4: DS12 COBIT 5: DSS05.05 DSS01.04, NCIIPC

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				to all employee, third parties and contractors. The requirements at minimum should include: 1. Lock the system when not in use. 2. Enable auto lock after a 10 minutes of inactivity.	Guidelines v2 (2015): PC12
PROTEC T-64	Access Control	BS.PR.AC 21	Identities and credentials are managed for authorized devices and users	The logs should be protected and be made accessible to authorized personnel only.	NIST 800-53 Rev 4: AU-9, ISO 27001:2013 A.12, COBIT 4: DS13 COBIT 5: DSS01.01 DSS01.03, NCIIPC Guidelines v2 (2015): IC 4 OC 10 DR 3
PROTEC T-65	Access Control	AD.PR.AC 1	Access permissions are managed, incorporating the principles of least privilege and separation of duties	Use of privileged accounts should be minimized i.e. highly privileged administrative accounts should not be used for high risk or day to day user activities. Administrators should use normal accounts for these purposes.	NIST 800-53 Rev 4: AC-2, AC-3, AC-6, CM-5, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1
PROTEC T-66	Access Control	AD.PR.AC 2	Access permissions are managed, incorporating the principles of least privilege and separation of duties	Administrator account logs should be regularly reviewed and checked for any suspicious activity.	NIST 800-53 Rev 4: AC-2, AC-3, AC-6, CM-5, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1
PROTEC T-67	Access Control	AD.PR.AC 3	Identities and credentials are managed for authorized devices and users	Blank passwords for any information system should not be allowed.	NIST 800-53 Rev 4: A-5, ISO 27001:2013 A.9.4.3, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): IC 3 IC4

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
PROTEC T-68	Access Control	AD.PR.AC 4	Identities and credentials are managed for authorized devices and users	User should never be allowed to select 'remember password' option during login, or in browsers.	NIST 800-53 Rev 4: A-5, ISO 27001:2013 A.9.4.3, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): IC 3 IC4
PROTEC T-69	Access Control	AD.PR.AC 6	Physical access to assets is managed and protected	The following security controls should be in place (at minimum) for physical security perimeter of the data center: 1. Electronic locks should be installed on all entry gates to Data center. 2. Visitor entry into restricted areas such as server room, data center, etc. should require explicit approval from the appropriate authority. 3. Entry logs should be maintained and monitored periodically. 4. There should be a biometric access control system or a similar level security at the entrance. 5. List of authorized personnel who enter the data center should be displayed at the entrance of the data center. 6. All activities inside data center should be monitored and recorded on a 24X7 basis by using CCTV.	NIST 800-53 Rev 4: PE-2, PE-3, PE-4, PE-5, ISO 27001:2013 A.11, COBIT 4: DS12 COBIT 5: DSS05.05 DSS01.04, NCIIPC Guidelines v2 (2015): PC12

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				7. No removable media should be allowed inside the data center.	
PROTEC T-70	Access Control	AD.PR.AC 7	Physical access to assets is managed and protected	Data center emergency procedures should be developed and, tested annually.	NIST 800-53 Rev 4: PE-2, PE-3, PE-4, PE-5, ISO 27001:2013 A.11, COBIT 4: DS12 COBIT 5: DSS05.05 DSS01.04, NCIIPC Guidelines v2 (2015): PC12
PROTEC T-71	Access Control	AD.PR.AC 8	Network integrity is protected, incorporating network segregation where appropriate	Network should be segmented to create multiple network zones to isolate traffic based on different security requirements. For example, network should be segmented by establishing a Militarized zone and DMZ. Any system accessible from the Internet should be on the DMZ, but DMZ systems should never contain any sensitive data.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): DR 3
PROTEC T-72	Access Control	AD.PR.AC 9	Network integrity is protected, incorporating network segregation where appropriate	Separate subnets/VLANs should be used to isolate wireless networks, if any, from wired network.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): DR 3
PROTEC T-73	Access Control	AD.PR.AC 10	Network integrity is protected, incorporating network segregation where appropriate	Proxy servers should be configured within a DMZ to filter both inbound and outbound connections.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): DR 3
PROTEC T-74	Access Control	AD.PR.AC 11	Network integrity is protected,	Internal network communications to DMZ should be	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13,

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
			incorporating network segregation where appropriate	restricted to access approved services only.	COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): DR 3
PROTEC T-75	Access Control	AD.PR.AC 12	Remote access is managed	Remote accesses should route through managed network access control points such as firewalls.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): DR 3
PROTEC T-76	Access Control	AD.PR.AC 13	Remote access is managed	Remote access to systems should be provided to only authorized users, through VPN or IPsec and use SSL for encryption of the channel.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): DR 3
PROTEC T-77	Access Control	AD.PR.AC 14	Remote access is managed	Remote access should be provided to users on a half-yearly basis to ensure that only authorized users continue to have remote access.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): DR 3
PROTEC T-78	Access Control	AD.PR.AC 15	Remote access is managed	There should be capability to expeditiously disconnect or disable remote access to any information system.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): DR 3
PROTEC T-79	Access Control	AD.PR.AC 16	Remote access is managed	Mail server should not run with root or system/administrat or privileges.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): IC 6
PROTEC T-80	Access Control	AD.PR.AC 17	Remote access is managed	A limit should be enforced on maximum size of attachment allowed and scan the attachment, for malware, before downloading.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): OC 5

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
PROTEC T-81	Access Control	AD.PR.AC 18	Remote access is managed	Mail server should be configured to block email from malicious domains, if required.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): OC 5
PROTEC T-82	Access Control	AD.PR.AC 19	Communications and control networks are protected	User access to cloud applications should be reviewed on a half-yearly basis to ensure that only authorized users continue to have access.	NIST 800-53 Rev 4: AC-2, NCIIPC Guidelines v2 (2015): OC8
PROTEC T-83	Access Control	AD.PR.AC 20	Communications and control networks are protected	Resources made available to or held by the cloud service provider should be returned or recovered after termination of the contract.	NIST 800-53 Rev 4: PS-4, PS-5, NCIIPC Guidelines v2 (2015): OC8
PROTEC T-84	Data Security	BS.PR.DS 1	Protections against data leaks are implemented	Critical data (Aadhaar, credit card number) should be transmitted over a secure channel.	NIST 800-53 Rev 4: SC-13, ISO 27001:2013 A.10.1, COBIT 4: PO6 AI2 DS5 COBIT 5: DSS05.05 , NCIIPC Guidelines v2 (2015): DR 3
PROTEC T-85	Data Security	BS.PR.DS 2	Protections against data leaks are implemented	Encryption protocols like Transport Layer Security (TLS) certificates, keys, digital signature etc. should be used for protection of stored and transmitted data as per applicable legal, statutory, and regulatory compliance obligations.	NIST 800-53 Rev 4: SC-13, ISO 27001:2013 A.10.1, COBIT 4: PO6 AI2 DS5 COBIT 5: DSS05.05 , NCIIPC Guidelines v2 (2015): OC 1
PROTEC T-86	Data Security	BS.PR.DS 3	Protections against data leaks are implemented	Only approved certificate authorities (CAs) should be allowed to issue certificates	NIST 800-53 Rev 4: SC-13, ISO 27001:2013 A.10.1, COBIT 4: PO6 AI2 DS5 COBIT 5:

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				within the department.	DSS05.05 , NCIIPC Guidelines v2 (2015): OC 1
PROTEC T-87	Data Security	BS.PR.DS 4	Protections against data leaks are implemented	Public keys should be used to establish trust are authenticated prior to use.	NIST 800-53 Rev 4: SC-13, ISO 27001:2013 A.10.1, COBIT 4: PO6 AI2 DS5 COBIT 5: DSS05.05 , NCIIPC Guidelines v2 (2015): OC 1
PROTEC T-88	Data Security	BS.PR.DS 5	Protections against data leaks are implemented	All servers used for authentication should have installed a valid certificate signed by a known trusted provider.	NIST 800-53 Rev 4: SC-13, ISO 27001:2013 A.10.1, COBIT 4: PO6 AI2 DS5 COBIT 5: DSS05.05 , NCIIPC Guidelines v2 (2015): OC 1
PROTEC T-89	Data Security	BS.PR.DS 6	Protections against data leaks are implemented	All servers and applications using SSL or TLS must have the certificates signed by a known, trusted provider.	NIST 800-53 Rev 4: SC-13, ISO 27001:2013 A.10.1, COBIT 4: PO6 AI2 DS5 COBIT 5: DSS05.05 , NCIIPC Guidelines v2 (2015): OC 1
PROTEC T-90	Data Security	BS.PR.DS 7	Protections against data leaks are implemented	New releases/ Patches should be tested before being implemented in the operational environment to ensure that there is no adverse impact on operations, application controls or security.	NIST 800-53 Rev 4: CM-2, ISO 27001:2013 A.12, COBIT 4: DS13 COBIT 5: DSS01.01 DSS01.03, NCIIPC Guidelines v2 (2015): IC 6
PROTEC T-91	Data Security	BS.PR.DS 8	Protections against data leaks are implemented	Updates to software should be installed in a timely manner (e.g. within 30 days of release or automatically when they become available from vendors).	NIST 800-53 Rev 4: CM-2, ISO 27001:2013 A.12, COBIT 4: DS13 COBIT 5: DSS01.01 DSS01.03, NCIIPC Guidelines v2 (2015): IC 6
PROTEC T-92	Data Security	AD.PR.DS 1	Protections against data leaks are implemented	Cryptanalysis (i.e. test to find weaknesses and the ease with which a cipher text can be	NIST 800-53 Rev 4: SC-13, ISO 27001:2013 A.10.1, COBIT 4: PO6 AI2 DS5 COBIT 5:

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				decoded) should be conducted periodically.	DSS05.05 , NCIIPC Guidelines v2 (2015): OC 1
PROTEC T-93	Data Security	AD.PR.DS 2	Data-in-transit is protected	Key management activities for secure key generation, ownership, distribution, archival, storage and revocation should be performed to protect the keys throughout their lifecycle.	NIST 800-53 Rev 4: SC-12, SC-17, ISO 27001:2013 A.10.1, COBIT 4: PO6 AI2 DS5 COBIT 5: DSS05.03 , NCIIPC Guidelines v2 (2015): OC 1
PROTEC T-94	Data Security	AD.PR.DS 3	Data-in-transit is protected	Key generation must be seeded from an industry standard random number generator.	NIST 800-53 Rev 4: SC-12, SC-17, ISO 27001:2013 A.10.1, COBIT 4: PO6 AI2 DS5 COBIT 5: DSS05.03 , NCIIPC Guidelines v2 (2015): OC 1
PROTEC T-95	Data Security	AD.PR.DS 4	Data-in-transit is protected	Keys that are lost or corrupted should be recovered as part of business continuity management, e.g. for recovery of encrypted information.	NIST 800-53 Rev 4: SC-12, SC-17, ISO 27001:2013 A.10.1, COBIT 4: PO6 AI2 DS5 COBIT 5: DSS05.03 , NCIIPC Guidelines v2 (2015): OC 1
PROTEC T-96	Maintenance	BS.PR.MA 1	Remote maintenance of organizational assets is approved, logged, and performed in a manner that prevents unauthorized access	Equipment or information asset should be removed from the premises only after approval from the appropriate authority.	NIST 800-53 Rev 4: MA-2, MA-6, ISO 27001:2013 A.11, COBIT 4: DS12 COBIT 5: DSS05.05 DSS01.04, NCIIPC Guidelines v2 (2015): PC12
PROTEC T-97	Maintenance	AD.PR.M A 1	Remote maintenance of organizational assets is approved, logged, and performed in	Annual maintenance plan of all the assets operating under CII should be designed and implemented. It should clearly indicate maximum	NCIIPC Guidelines v1 (2013) Control 14

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
			a manner that prevents unauthorized access	downtime for any asset. Maintenance plan should be reviewed periodically.	
PROTEC T-98	Protective Technology	BS.PR.PT 1	Communications and control networks are protected	Hardening of network devices should be done as per Minimum baseline security standards.	NIST 800-53 Rev 4: AC-3, AC-17, AC-18, AC-20, SC-7, SC-8, SC-10, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): OC 7 OC 10
PROTEC T-99	Protective Technology	BS.PR.PT 2	Communications and control networks are protected	Automated vulnerability scanning tools should be run regularly against all network devices to manage any identified vulnerabilities within an agreed time frame.	NIST 800-53 Rev 4: AC-3, AC-17, AC-18, AC-20, SC-7, SC-8, SC-10, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): OC 5
PROTEC T-100	Protective Technology	BS.PR.PT 3	Communications and control networks are protected	All network ports, protocols and service should be disabled by default. All port, protocols or services should be used only after approval from an appropriate authority.	NIST 800-53 Rev 4: AC-3, AC-17, AC-18, AC-20, SC-7, SC-8, SC-10, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): OC 7 OC 10
PROTEC T-101	Protective Technology	BS.PR.PT 4	Communications and control networks are protected	Access to the administrative interfaces (for e.g. interface used to manage firewall configuration etc.) should be prevented from the Internet, unless there is a clear and documented business need.	NIST 800-53 Rev 4: AC-3, AC-17, AC-18, AC-20, SC-7, SC-8, SC-10, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): IC2
PROTEC T-102	Protective Technology	BS.PR.PT 5	Communications and control	Asset identification mechanism should be established (e.g., MAC binding) to	NIST 800-53 Rev 4: AC-3, AC-17, AC-18, AC-20, SC-7, SC-8, SC-10, ISO

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
			networks are protected	ensure that only authorized systems can be connected to network.	27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): OC 7 OC 10
PROTEC T-103	Protective Technology	AD.PR.PT 1	Communications and control networks are protected	All mobile devices should have latest patches and anti-virus installed.	NIST 800-53 Rev 4: AC-17, AC-18, AC-19, ISO 27001:2013 A.6.2.1, COBIT 4: PO6 DS5 COBIT 5: DSS05 , NCIIPC Guidelines v2 (2015): OC 4
PROTEC T-104	Protective Technology	AD.PR.PT 2	Communications and control networks are protected	Mobile devices should not be used to store sensitive data / information (e.g., top secret, secret) without approval from appropriate authority.	NIST 800-53 Rev 4: AC-17, AC-18, AC-19, ISO 27001:2013 A.6.2.1, COBIT 4: PO6 DS5 COBIT 5: DSS05 , NCIIPC Guidelines v2 (2015): OC 4
PROTEC T-105	Protective Technology	AD.PR.PT 3	Communications and control networks are protected	Auto lock should be enabled to automatically lock the device in case the device is left idle for more than 3 minutes.	NIST 800-53 Rev 4: AC-17, AC-18, AC-19, ISO 27001:2013 A.6.2.1, COBIT 4: PO6 DS5 COBIT 5: DSS05 , NCIIPC Guidelines v2 (2015): OC 4
PROTEC T-106	Protective Technology	AD.PR.PT 4	Communications and control networks are protected	Mobile application should not hold sensitive data in memory longer than required, and memory is cleared explicitly after use.	NIST 800-53 Rev 4: AC-17, AC-18, AC-19, ISO 27001:2013 A.6.2.1, COBIT 4: PO6 DS5 COBIT 5: DSS05 , NCIIPC Guidelines v2 (2015): OC 4
PROTEC T-107	Protective Technology	AD.PR.PT 5	Communications and control networks are protected	Third party components (such as libraries and frameworks) used by the mobile application, should be identified, and checked for known vulnerabilities.	NIST 800-53 Rev 4: AC-17, AC-18, AC-19, ISO 27001:2013 A.6.2.1, COBIT 4: PO6 DS5 COBIT 5: DSS05 , NCIIPC Guidelines v2 (2015): OC 4
PROTEC T-108	Protective Technology	AD.PR.PT 6	Communications and control	Mobile application should be digitally signed and	NIST 800-53 Rev 4: AC-17, AC-18, AC-19, ISO 27001:2013 A.6.2.1, COBIT 4:

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
			networks are protected	provisioned with valid certificate.	PO6 DS5 COBIT 5: DSS05 , NCIIPC Guidelines v2 (2015): OC 4
PROTEC T-109	Protective Technology	AD.PR.PT 7	Removable media is protected and its use restricted according to policy	The business requirements for the use of a removable media (e.g., pen drive, external hard disk and other similar devices) should be identified and documented.	NIST 800-53 Rev 4: MP-2, MP-4, MP-5, MP-6, MP-7, ISO 27001:2013 A.8.3, COBIT 4: PO2 DS11 COBIT 5: DSS01.01 , NCIIPC Guidelines v2 (2015): OC 4
PROTEC T-110	Protective Technology	AD.PR.PT 8	Removable media is protected and its use restricted according to policy	All removable media in use (e.g., pen drive, external hard disk and other similar devices) should be identified as part of the asset register.	NIST 800-53 Rev 4: MP-2, MP-4, MP-5, MP-6, MP-7, ISO 27001:2013 A.8.3, COBIT 4: PO2 DS11 COBIT 5: DSS01.01 , NCIIPC Guidelines v2 (2015): OC 4
PROTEC T-111	Protective Technology	AD.PR.PT 9	Removable media is protected and its use restricted according to policy	Removable media should be granted only to authorized personnel after approval of the appropriate authority.	NIST 800-53 Rev 4: MP-2, MP-4, MP-5, MP-6, MP-7, ISO 27001:2013 A.8.3, COBIT 4: PO2 DS11 COBIT 5: DSS01.01 , NCIIPC Guidelines v2 (2015): OC 4
PROTEC T-112	Protective Technology	AD.PR.PT 10	Removable media is protected and its use restricted according to policy	All Removable media should be encrypted using encryption software approved by the department.	NIST 800-53 Rev 4: MP-2, MP-4, MP-5, MP-6, MP-7, ISO 27001:2013 A.8.3, COBIT 4: PO2 DS11 COBIT 5: DSS01.01 , NCIIPC Guidelines v2 (2015): OC 4
PROTEC T-113	Protective Technology	AD.PR.PT 11	Removable media is protected and its use restricted according to policy	The auto-run feature should be disabled (to prevent software programs running automatically when removable storage media is connected to a computer or when network	NIST 800-53 Rev 4: MP-2, MP-4, MP-5, MP-6, MP-7, ISO 27001:2013 A.8.3, COBIT 4: PO2 DS11 COBIT 5: DSS01.01 , NCIIPC Guidelines v2 (2015): OC 4

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				folders are accessed).	
PROTEC T-114	Protective Technology	AD.PR.PT 12	Removable media is protected and its use restricted according to policy	Removable media (e.g., hard disk) should be disposed, when not required, in a secure (e.g., de-gauss or electronically wiping drives) way by authorized person.	NIST 800-53 Rev 4: MP-2, MP-4, MP-5, MP-6, MP-7, ISO 27001:2013 A.8.3, COBIT 4: PO2 DS11 COBIT 5: DSS05.08 , NCIIPC Guidelines v2 (2015): OC 9
PROTEC T-115	Protective Technology	AD.PR.PT 13	Communications and control networks are protected	The default password of the Wi-Fi router should be changed, and administrative access should be provided to the authorized individual only.	NIST 800-53 Rev 4: AC-3, AC-17, AC-18, AC-20, SC-7, SC-8, SC-10, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): OC 7
PROTEC T-116	Protective Technology	AD.PR.PT 14	Communications and control networks are protected	Wireless network should be implemented after due approval of ISO.	NIST 800-53 Rev 4: AC-3, AC-17, AC-18, AC-20, SC-7, SC-8, SC-10, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): OC 7
PROTEC T-117	Protective Technology	AD.PR.PT 15	Communications and control networks are protected	Wi-Fi signals should be restricted within the office premise only. Department should periodically change (e.g., three months) the user password to access the Wi-Fi.	NIST 800-53 Rev 4: AC-3, AC-17, AC-18, AC-20, SC-7, SC-8, SC-10, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): OC 7
PROTEC T-118	Protective Technology	AD.PR.PT 16	Communications and control networks are protected	All wireless traffic leverages should at least have Advanced Encryption Standard (AES) encryption used with at least Wi-Fi Protected Access 2 (WPA2) protection.	NIST 800-53 Rev 4: AC-3, AC-17, AC-18, AC-20, SC-7, SC-8, SC-10, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): OC 7
PROTEC T-119	Protective Technology	AD.PR.PT 17	Communications and control	User access to Wi-Fi should be protected through	NIST 800-53 Rev 4: AC-3, AC-17, AC-18, AC-20, SC-7,

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
			networks are protected	certificate based authorization.	SC-8, SC-10, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): OC 7
PROTEC T-120	Protective Technology	AD.PR.PT 18	Communications and control networks are protected	Web interface should have the ability to use HTTPS to protect transmitted information.	NCIIPC Guidelines v1 (2013) Control 25 , IoT Security Guidance by OWASP: I1
PROTEC T-121	Protective Technology	AD.PR.PT 19	Communications and control networks are protected	All communication between different system components and between the system and the internet should be encrypted.	NCIIPC Guidelines v1 (2013) Control 35 , IoT Security Guidance by OWASP: I4
PROTEC T-122	Protective Technology	AD.PR.PT 20	Communications and control networks are protected	Any device should not make network ports and/or services available to the internet via UPnP protocols.	NCIIPC Guidelines v1 (2013) Control 12 , IoT Security Guidance by OWASP: I3
PROTEC T-123	Protective Technology	AD.PR.PT 21	Communications and control networks are protected	All devices should operate with a minimal number of network ports active.	IoT Security Guidance by OWASP: I3
PROTEC T-124	Protective Technology	AD.PR.PT 22	Communications and control networks are protected	Minimum number of physical external ports should be allowed on the devices.	IoT Security Guidance by OWASP: I10
PROTEC T-125	Protective Technology	AD.PR.PT 23	Communications and control networks are protected	Cloud-based web interfaces should have two factor authentication and account lockout mechanism enabled to prevent unauthorized access.	IoT Security Guidance by OWASP: I6
PROTEC T-126	Protective Technology	AD.PR.PT 24	Communications and control networks are protected	The cloud provider should have a transparent response process in place and sufficient mechanisms to share information	NIST 800-53 Rev 4: AC-2, NCIIPC Guidelines v2 (2015): OC8

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				during and after an incident.	
DETECT -1	Security Continuous Monitoring	BS.DE.C M 1	Monitoring for unauthorized personnel, connections, devices, and software is performed	Software installed on devices should be licensed.	NIST 800-53 Rev 4: CM-8, ISO 27001:2013 A.12, COBIT 4: DS13 COBIT 5: BAI09.05 , NCIIPC Guidelines v2 (2015): IC 6
DETECT -2	Security Continuous Monitoring	BS.DE.C M 2	Personnel activity is monitored to detect potential cybersecurity events	Any software that is no longer supported and doesn't receive regular fixes should be removed.	NIST 800-53 Rev 4: CM-5, CM-7(4), CM-7(5), CM-11, ISO 27001:2013 A.12, COBIT 4: DS13 COBIT 5: DSS01.01 DSS01.03, NCIIPC Guidelines v2 (2015): IC 6
DETECT -3	Security Continuous Monitoring	BS.DE.C M 3	Monitoring for unauthorized personnel, connections, devices, and software is performed	Event logs recording the user-activities, exceptions, security events and system faults should be maintained and stored to assist in future investigations.	NIST 800-53 Rev 4: AU-3, AU-6, AU-11, AU-12, AU-14, ISO 27001:2013 A.12, COBIT 4: DS13 COBIT 5: DSS01.01 DSS01.03, NCIIPC Guidelines v2 (2015): IC 4 OC 10 DR 3
DETECT -4	Security Continuous Monitoring	BS.DE.C M 4	Monitoring for unauthorized personnel, connections, devices, and software is performed	Department should identify security personnel and/or system administrators to identify anomalies in logs. They should then actively review the anomalies, document their findings.	NIST 800-53 Rev 4: AU-3, AU-6, AU-11, AU-12, AU-14, ISO 27001:2013 A.12, COBIT 4: DS13 COBIT 5: DSS01.01 DSS01.03, NCIIPC Guidelines v2 (2015): IC 4 OC 10 DR 3
DETECT -5	Security Continuous Monitoring	BS.DE.C M 5	Monitoring for unauthorized personnel, connections, devices, and software is performed	Audit log settings for each hardware device and the software installed on it, should be periodically be validated to ensure that logs include a date, timestamp, source addresses,	NIST 800-53 Rev 4: AU-3, AU-6, AU-11, AU-12, AU-14, ISO 27001:2013 A.12, COBIT 4: DS13 COBIT 5: DSS01.01 DSS01.03, NCIIPC Guidelines v2 (2015): IC 4 OC 10 DR 3

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				destination addresses, and various other relevant information.	
DETECT -6	Security Continuous Monitoring	BS.DE.C M 6	Monitoring for unauthorized personnel, connections, devices, and software is performed	The logs of the systems / devices should be captured to ensure against loss of events during peak activity.	NIST 800-53 Rev 4: AU-3, AU-6, AU-11, AU-12, AU-14, ISO 27001:2013 A.12, COBIT 4: DS13 COBIT 5: DSS01.01 DSS01.03, NCIIPC Guidelines v2 (2015): IC 4 OC 10 DR 3
DETECT -7	Security Continuous Monitoring	AD.DE.C M 1	Personnel activity is monitored to detect potential cybersecurity events	User activity should be monitored, particularly access to sensitive information and the use of privileged account actions to identify any malicious activity.	NIST 800-53 Rev 4: AC-2, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1
DETECT -8	Security Continuous Monitoring	AD.DE.C M 2	Personnel activity is monitored to detect potential cybersecurity events	Use of administrative privileged functions should be monitored for anomalous behavior.	NIST 800-53 Rev 4: AC-2, AC-3, AC-6, CM-5, ISO 27001:2013 A.9.2, COBIT 4: DS5 COBIT 5: DSS05.04 , NCIIPC Guidelines v2 (2015): IC 1
DETECT -9	Security Continuous Monitoring	AD.DE.C M 3	Malicious code is detected	Malware protection software should be installed on all the systems / devices, as applicable.	NIST 800-53 Rev 4: AT-2, SI-3, ISO 27001:2013 A.12, COBIT 4: DS5 COBIT 5: DSS05.01 , NCIIPC Guidelines v2 (2015): OC 11
DETECT -10	Security Continuous Monitoring	AD.DE.C M 4	Malicious code is detected	Malware protection software (including program code and malware signature files) should be up-to-date with signature files updated at least daily.	NIST 800-53 Rev 4: AT-2, SI-3, ISO 27001:2013 A.12, COBIT 4: DS5 COBIT 5: DSS05.01 , NCIIPC Guidelines v2 (2015): OC 11
DETECT -11	Security Continuous Monitoring	AD.DE.C M 5	Malicious code is detected	Malware protection software should be configured to	NIST 800-53 Rev 4: AT-2, SI-3, ISO 27001:2013 A.12,

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				perform regular scans of all files (e.g. daily).	COBIT 4: DS5 COBIT 5: DSS05.01 , NCIIPC Guidelines v2 (2015): OC 11
DETECT -12	Security Continuous Monitoring	AD.DE.C M 6	The network is monitored to detect potential cybersecurity events	There should be support or arrangement for network forensics/forensic investigation/DDO S mitigation services on stand-by.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): IC 4, RBI Cyber Security Framework in Banks (2016)- Baseline Cyber Security and Resilience Requirements Point 22.1
DETECT -13	Security Continuous Monitoring	AD.DE.C M 7	The network is monitored to detect potential cybersecurity events	Cyber drills should be conducted periodically and actively under the aegis of Cert-IN and IDRBT.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): IC 4, RBI Cyber Security Framework in Banks (2016)-Baseline Cyber Security and Resilience Requirements Point 22.2
DETECT -14	Security Continuous Monitoring	AD.DE.C M 8	The network is monitored to detect potential cybersecurity events	The systems should be put in place as a part of the Cyber SoC and address the following aspects: a). Dynamic Behavior Analysis. – Preliminary static & dynamic analysis and collecting Indicators of Compromise (IOC). b). Analytics with good dash board, showing the Geo-location of the IP's.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): IC 4, RBI Cyber Security Framework in Banks (2016)-Cyber SoC: Points to be considered Point 4

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				c). Counter response and Honeypot services.	
DETECT -15	Security Continuous Monitoring	AD.DE.C M 9	The network is monitored to detect potential cybersecurity events	Anti-phishing/anti-rogue app services should be subscribed to from external service providers for identifying and taking down phishing websites/rogue applications.	NIST 800-53 Rev 4: AC-4, SC-7, ISO 27001:2013 A.13, COBIT 4: DS5 COBIT 5: DSS05.02 , NCIIPC Guidelines v2 (2015): IC 4, RBI Cyber Security Framework in Banks (2016)-Baseline Cyber Security and Resilience Requirements Point 14.1
DETECT -16	Security Continuous Monitoring	AD.DE.C M 10	The network is monitored to detect potential cybersecurity events	Review of all public interfaces should be conducted on an annual basis.	NIST 800-53 Rev 4: CA-2, SA-11, ISO 27001:2013 A.14, COBIT 4: AI1 AI2 AI3 COBIT 5: BAI03 , NCIIPC Guidelines v2 (2015): IC 6
DETECT -17	Security Continuous Monitoring	AD.DE.C M 11	Vulnerability scans are performed	Prior to deployment, all publicly available websites should be tested and it should be ensured that the identified vulnerabilities are fixed prior to publishing over internet.	NIST 800-53 Rev 4: CA-2, SA-11, ISO 27001:2013 A.14, COBIT 4: AI1 AI2 AI3 COBIT 5: BAI03 , NCIIPC Guidelines v2 (2015): OC 5
DETECT -18	Security Continuous Monitoring	AD.DE.C M 12	Vulnerability scans are performed	All Internet-accessible web applications should be scanned for vulnerabilities on a half-yearly basis.	NIST 800-53 Rev 4: CA-2, SA-11, ISO 27001:2013 A.14, COBIT 4: AI1 AI2 AI3 COBIT 5: BAI03 , NCIIPC Guidelines v2 (2015): OC 5
DETECT -19	Security Continuous Monitoring	AD.DE.C M 13	Communications and control networks are protected	Performance of the cloud provider should be continually assessed and the quality of the services to ensure all contract	NIST 800-53 Rev 4: SA-12, NCIIPC Guidelines v2 (2015): OC8

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				obligations are being met.	
DETECT-20	Analysis	BS.DE.AN 1	Response plans (Incident Response and Business Continuity) and recovery plans (Incident Recovery and Disaster Recovery) are in place and managed	Criterion to prioritize incident should be defined.	NIST 800-53 Rev 4: IR-8, ISO 27001:2013 A.16, COBIT 4: PO6 DS5 DS8 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): OC2
DETECT-21	Analysis	BS.DE.AN 2	Response plans (Incident Response and Business Continuity) and recovery plans (Incident Recovery and Disaster Recovery) are in place and managed	Resolution time and response time for each priority should be defined.	NIST 800-53 Rev 4: IR-8, ISO 27001:2013 A.16, COBIT 4: PO6 DS5 DS8 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): OC2
DETECT-22	Analysis	AD.DE.A N 1	Response plans (Incident Response and Business Continuity) and recovery plans (Incident Recovery and Disaster Recovery) are in place and managed	Security alarms should be processed in real-time based on indicated severity levels.	NIST 800-53 Rev 4: IR-4, ISO 27001:2013 A.16, COBIT 4: PO5 AI4 DS8 DS10 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): OC2
DETECT-23	Anomalies and Events	AD.DE.A E 1	Detected events are analyzed to understand attack targets and methods	The type, volume and frequency of information security incidents should be identified. Information gained from the evaluation	NIST 800-53 Rev 4: IR-8, ISO 27001:2013 A.16, COBIT 4: PO6 DS5 DS8 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): OC2

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
				of the past information security incidents should be used to identify recurring or high impact incidents.	
RESPON D-1	Communication	BS.RS.CO 1	Personnel know their roles and order of operations when a response is needed	Appropriate channels such as ticket portal should be established to report security incidents as quickly as possible.	NIST 800-53 Rev 4: IR-8, ISO 27001:2013 A.16, COBIT 4: PO6 DS5 DS8 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): OC2
RESPON D-2	Communication	BS.RS.CO 2	Personnel know their roles and order of operations when a response is needed	Security incidents should be notified to CERT-In, in case of breach of security as per the process. These incidents could be loss of confidentiality, disruption of data, denial of service availability etc.	NIST 800-53 Rev 4: AU-6, IR-6, ISO 27001:2013 A.16, COBIT 4: PO6 DS5 DS8 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): OC2
RESPON D-3	Communication	BS.RS.CO 3	Personnel know their roles and order of operations when a response is needed	Awareness training should be held to enable employee to proactively report weakness in infrastructure. Root cause analysis of the weakness should be performed and timely closure of the same should be ensured.	NIST 800-53 Rev 4: IR-4, ISO 27001:2013 A.16, COBIT 4: AI2 DS5 DS8 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): OC2
RESPON D-4	Response planning	AD.RS.RP 1	Response plan is executed during or after an event	Redundant information systems should be tested to ensure the failover from one component to another component works as intended.	NIST 800-53 Rev 4: CP-4, ISO 27001:2013 A.17, COBIT 4: PO3 PO9 DS4 DS8 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): DR 1 DR 2 DR 3
RESPON D-5	Response planning	AD.RS.RP 2	Response plan is executed	Consider Mean time to Failure (MTFR) for all	NCIIPC Guidelines v1 (2013) Control 23

Control Function	Control Category	Control Unique Identifier	Control Sub category	Control Statement	Informative References
			during or after an event	assets and provide the substitute of the assets through active and stand-by mechanism. The transfer of responsibilities in active and standby mode should not impact operations.	
RESPON D-6	Response planning	AD.RS.RP 3	Response plan is executed during or after an event	Run mock DoS scenarios to validate preparedness of the CII in tackling such attacks.	NCIIPC Guidelines v1 (2013) Control 25
RESPON D-7	Response planning	AD.RS.RP 4	Response plan is executed during or after an event	Better collaboration on 24*7 basis with ISP for tackling DoS/DDoS attacks should be in place, also exploring the ISPs capability in tackling DoS attacks.	NCIIPC Guidelines v1 (2013) Control 25
RECOVER-1	Improvements	BS.RC.IM 1	Recovery plan is executed during or after an event	Evidence relating to the incident should be collected, and retained.	NIST 800-53 Rev 4: AU-4*, AU-9*, AU-10(3)*, AU-11*, ISO 27001:2013 A.16, COBIT 4: AI2 DS5 DS8 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): OC2
RECOVER-2	Improvements	AD.RC.IM 1	Recovery plans incorporate lessons learned	Information gained from the evaluation of the past information security incidents should be used to identify recurring or high impact incidents.	NIST 800-53 Rev 4: IR-4, ISO 27001:2013 A.16, COBIT 4: PO5 AI4 DS8 DS10 COBIT 5: APO12 , NCIIPC Guidelines v2 (2015): OC2

5. Industry Sector Specific Requirements

As each industry is different and each organization is different, the “one size fits all” doctrine cannot be adopted. AP – CSF provides flexibility and encourages organizations, in the public as well as private sector, to create an individual profile based on Inherent Risk Assessment to assess their current cyber security posture and further define the cyber security target state.

AP – CSF mandates that for achieving the target cyber security posture, the organizations should analyze and implement “Baseline Cyber Security Controls”, listed in the aforementioned section and choose the additional controls listed in the “Advanced Cyber Security Controls” appropriate to their particular department/ organization. Figure 5 depicts the admixture of baseline, advanced and the sector-specific controls.

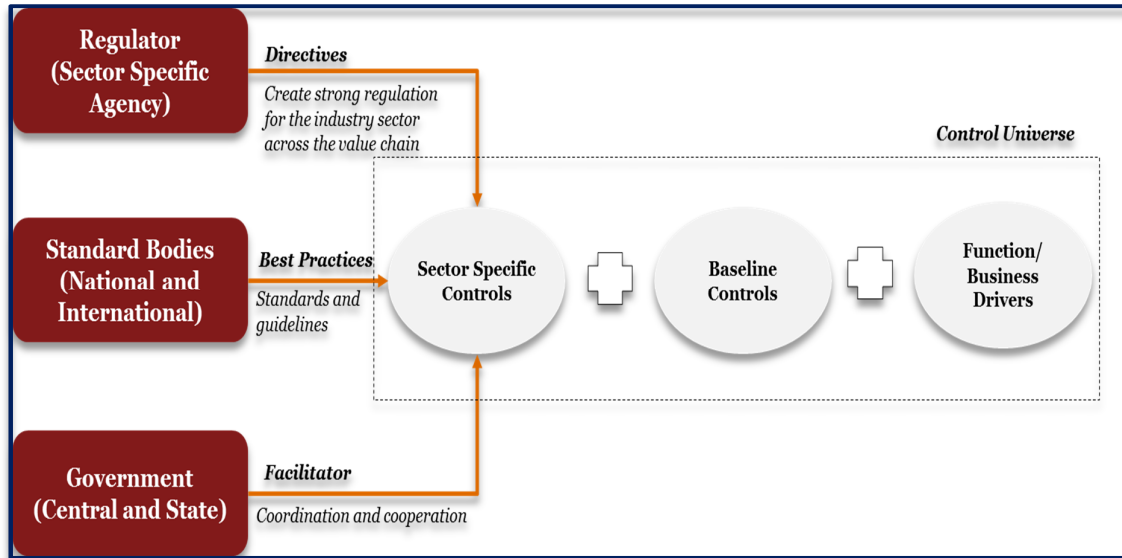


Figure 4: Control Universe with Industry Sector and Organization Context

The Table 2 depicts the contextual elements which can be considered while adopting the sector-specific security controls:

Table 2: Industry Sector specific concerns

Industry Sector	Cyber Security Concerns	Industry Standards
<i>Finance</i>	Changing ecosystem with new actors such as payment vendors, third party service providers, machines (ATMs, POS etc.), multiple channels including internet, mobile and social media has made the financial enterprise boundary less. Integrity and authenticity of financial transactions, trustworthiness of the players in the value chain and availability of systems relies on robust security controls dealing with new threat vectors.	PCI-DSS, IOSCO guidelines, Regulatory guidance (as applicable) by RBI, SEBI, IRDAI
<i>Health Care</i>	Digitized/electronic records containing the personal health information (not perishable) resulting into security and privacy concerns; Telemedicine, remote operations and impact of hacking into patient health care equipment's making them either unavailable or resulting into malfunctioning.	HIPAA, HITRUST Information Security Policy and Privacy Policy notified by National Health Authority, GoI.
<i>Education</i>	Education sector is embarking on a digital journey for reaching the masses with online education, exams and results with student as both a benefactor and driver for the future economic growth. Concerns arising from the sector are	NICE framework for the cyber roles, Data security standards and regulations

Industry Sector	Cyber Security Concerns	Industry Standards
	duplication of degree certificates, IPR theft and impact of mass outreach of the content.	
<i>Manufacturing</i>	Cyber security risks to the manufacturing sector include everything from operational downtime, to physical damage, product manipulation, supply chain risks and the theft of intellectual property and sensitive data. Manufacturers are increasingly using cloud, data analytics and mobile to improve their connectivity and infrastructure. This means a larger attack surface from which cyber criminals can infiltrate.	TISAX, VDA guidelines
<i>Energy, Oil & Gas</i>	Smart Grids, Power Generation, Transmission and Distribution are all getting automated where the operational technology systems and industrial control systems are getting integrated with the IT systems. There are evidences from global incidents where the malwares have resulted into blackouts for the entire area.	ISO 27019:2017, ISA 99, NERC-CIP guidelines
<i>Transportation</i>	The transportation industry is considered part of the critical infrastructure of a country, and it is considered a privileged target for hackers. The transportation sector is increasingly vulnerable to cyber threats as a result of the growing reliance on cyber-based control, navigation, tracking, positioning and communications systems, as well as the ease with which malicious actors can exploit cyber systems serving transportation.	DHS guidance for cyber security in transportation sector
<i>Telecom</i>	Telecoms companies, their core infrastructure and the large volumes of personal data they hold on subscribers, all represent an obvious target for malicious actors. Compared to other industries, telecom companies are expected to be tech-savvy and often have a large consumer-facing footprint. They face particular cyber security concerns as a result of their interconnected nature and the reliance upon international standards in their operations.	TRAI and DoT guidelines

6. Audit and Assurance Framework

The Audit & Assurance Framework provides independent supervision and drives the management commitment for proper design, implementation, sustenance and improvement of cyber security posture meeting the defined business goals and security objectives.

The elements of an effective Audit & Assurance framework are

1. Defining of objectives
2. Defining of risks associated with achieving the objectives
3. Defining controls to manage the risks
4. Testing effectiveness of the controls
5. Identification of gaps in controls
6. Remediation of the identified gaps

The Table 3 specifies the various levels of assurance along with objective and proposed method of verification which should be adopted by the department/organization.

Table 3: Assurance Levels

Assurance Level	Objective	Method of Verification
Level 1: Assurance of compliance to cyber security baseline controls	The organization has implemented cyber security baseline controls defined in the AP-CSF, based on clear understanding of risks, threats, & vulnerabilities.	Self-assessment or independent third-party audit report. Frequency: Annual
Level 2: Assurance of an adequate cyber security posture	1. The Organization has complied with both the Baseline and Advanced controls prescribed by AP-CSF. 2. The organization has also conducted cyber security posture verification (by way of security testing of its IT infrastructure involving VA/PT, application security testing, code walk-throughs, source code reviews).	Bi-annual security testing of IT infrastructure involving VA/PT, application security testing, code walk-throughs, secure code reviews etc. and a report is available for the same Frequency: Bi-Annual
Level 3: Assurance of IT security crisis response & ability to resist cyber attacks	The organization has participated in the cyber security drills to have its cyber security crisis response & ability to resist cyber-attacks tested and verified	Cyber security drill results with CERT-In/ AP-CRT (AP-CSOC) Frequency: Annual

6.1. Guidelines for Audit & Assurance Function

Audit Charter

1. The function should document the audit plan properly in an **audit charter** which defines the following:
 - i. Authority, purpose, responsibilities and limitation of the audit
 - ii. Independence and accountability of the audit as well as assurance function
 - iii. Roles and responsibilities of the individuals
 - iv. Industry standards to be followed for the audit & assurance engagement
2. The function should review the charter at least annually or when there is a change in responsibilities
3. The function should formally communicate the audit charter to auditee for the engagement

Organizational Independence

1. The function should report to level within the organization that provides organizational independence.
2. The function should disclose the details of the impairment to the appropriate parties if independence is impaired in fact or appearance.
3. The function should avoid non-audit roles that require assumption of management responsibilities.
4. The function should address independence and accountability of the audit function in its charter and/or engagement letter

Professional Independence

1. The audit and assurance professionals should conduct the engagement with an impartial and unbiased frame of mind in addressing assurance issues and reaching conclusions.
2. The professionals should be independent at all times
3. The professionals should disclose the details of impairment to the appropriate parties if independence is impaired in factor appearance.
4. The professionals should avoid non-audit roles that require assumption of management responsibilities because such roles could impair future independence.

Reasonable Expectations

1. The professionals should undertake the assurance engagement only if the work can be successfully completed in accordance with professional standards
2. The professionals should review the scope of the assurance engagement to determine that it is clearly documented and permits a conclusion to be drawn on the subject matter.
3. The professional should identify and address any restrictions being placed upon the engagement to be performed, including access to appropriate, relevant and timely information.

Proficiency

1. The professionals should demonstrate that sufficient professional competencies (skills, knowledge and experience relevant to the planned engagement) are available prior to the commencement of the work.
2. The professional should provide reasonable assurance when leading a team to conduct assurance engagement that all team members have the appropriate level of professional competency for the work they perform.
3. The professional should have sufficient knowledge of key areas to enable conduct of the assurance engagements effectively and efficiently, along with any specialists used and other team members.
4. The professional should update professional knowledge continually through educational courses, seminars, conferences, webcasts and on-the-job training to provide a level of professional service commensurate with the requirements of the assurance role

7. Implementation Imperatives

Experience informs that conceptual frameworks are important and they help in guiding the implementation efforts; however, it is the actual implementation which is vital for translation of objectives to reality. This section focuses on the implementation imperatives i.e.

- the step by step approach to implement the framework;

- the operating model
- governance to oversee the implementation;
- supporting guidelines and toolkits; and
- a nodal body to assist implementation.

7.1. Step by Step Approach

The following step-by-step approach is recommended for implementing the AP CSF to ensure an improved security posture of the state through both individual and collaborative effort:

7.1.1. Identify applicable controls as per business requirements

All the controls defined under the UCM (Unified Control Matrix) (incl. Baseline and Advanced security controls) may not be applicable to the organization implementing the framework. Each organization should identify the applicable and relevant controls commensurate with the business it conducts.

As the business ecosystem is rapidly changing with the introduction of technology blurring boundaries between functions, it is suggested that organizations should evaluate the appropriateness of controls at least once a year or after a major business change.

7.1.2. Create Cyber Security Policies

Following the identification of the set of controls to be adopted, organizations should create cyber security policies and procedures to provide a strategic direction to the organization.

7.1.3. Evaluate Inherent Risk for business and create current profile

Organizations should evaluate the **inherent risk** to the core business it conducts, basing on multiple factors such as generic and specific threats to the information assets of the organization and the vulnerabilities of the existing assets. The following guidelines may be considered:

- Adopt an industry standard methodology for risk assessment such as ISO 27005 and ISO 31000.
- determine the risk tolerance
- evaluate business impact from potential cyber vulnerabilities
- deploy controls commensurate to the risk

After conducting risk assessment as above, the organization may update the Security Policy prepared in Step 2 and create the Current Risk Profile.

7.1.4. Create a Target Profile

Organization should create a Target Profile which it wants to develop with desired security outcomes. The organization may also consider influences and requirements of external stakeholders such as sector entities, customers, and business partners when creating a Target Profile.

7.1.5. Determine, Analyze and Prioritize gaps

The organization should compare the Current Profile and the Target Profile to determine gaps. It should then create a prioritized action plan to address those gaps that draws upon mission drivers, a cost/benefit analysis, and understanding of risk to achieve the outcomes in the Target Profile.

7.1.6. Implement Controls for prioritized gaps

Execute the action plan, on the basis of the prioritized gaps to minimize the inherent risk. Once the controls are implemented as per the Target Profile, organization should consider that as new normal and continuously evolve for improvement.

7.1.7. Continuous Improvement

Monitoring and measurement provides a basis for strong trusted relationships both inside and outside the organization. Effective monitoring continuously checks for the anomalous activity to continuously uphold compliance requirements and proactively protect against attacks. Organisations should monitor the controls implemented for effectiveness using PDCA approach (Plan – Do – Check – Act) and strive for continuous improvement.

7.2. Implementation Governance

A robust operating model is imperative for successful implementation of the AP – CSF. An organization structure is proposed at the State level to govern the cyber security program with an Apex Committee that will be assisted by an Advisory Board, as depicted in the figure 5. Apex Committee is supported by three Sub Committees, which will primarily drive the implementation of key areas for the state viz.

1. Protection of Critical Information Infrastructure (Government Infrastructure)
2. Capacity Building, and
3. Strengthening the law enforcement agencies (Forensics)

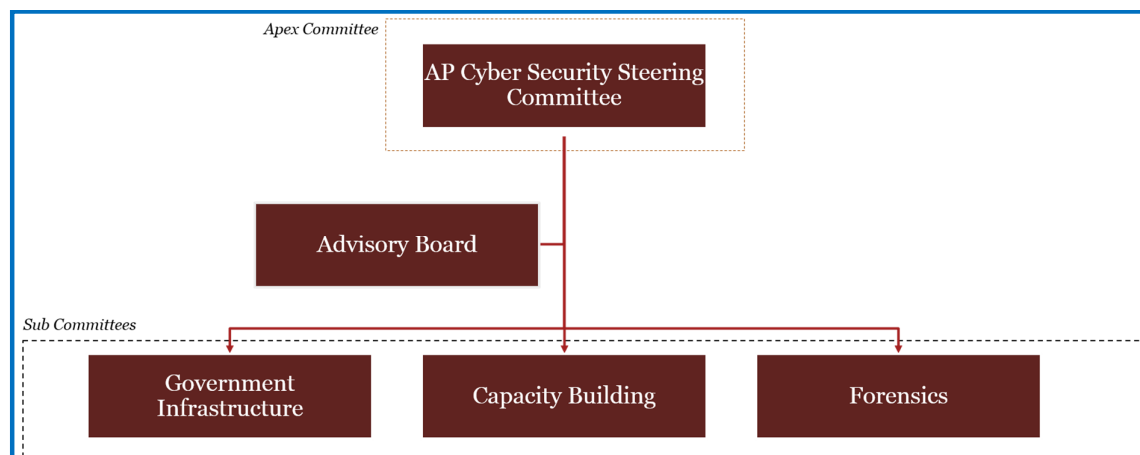


Figure 5: Governance Structure

7.2.1. Apex Committee

1. Government of AP may constitute an Apex Committee headed by the Chief Secretary, and comprising of the Secretaries of key Departments involved in the implementation of AP CSF.
2. The Apex Committee is required to play a very significant role in the implementation of AP CSF vital for the overall governance. The Apex Committee would be the supreme body for AP-CSF and could meet twice in a year.
3. The Apex Committee will provide the strategic direction and vision to the program and would undertake high level program review from time to time and resolve inter-departmental issues. It would also lay down the broad policy guidelines as well as specific responsibilities for the implementation of AP-CSF.
4. The Apex Committee may induct expert members of the Advisory Board for better and informed decision making.

Suggested Composition of Apex Committee:

1	Chief Secretary	Chairperson
2	Director General of Police	Member
3	Special Chief Secretary, Finance Department	Member
4	Special Chief Secretary, Revenue Department	Member
5	Special Chief Secretary, Medical, Health & Family Welfare Department	Member
6	Principal Secretary, Energy, I&I Department	Member
7	Principal Secretary, IT,E&C Department	Member
8	Principal Secretary, Real Time Governance	Member
9	Principal Secretary, Higher Education Department	Member
10	Additional Director General of Police (CID)	Member
11	Special Secretary, IT,E&C Department	Member
12	Chief Executive Officer, AP Core Digital Data Authority	Member
13	Chief Executive Officer, e-Pragati	Member
14	Chief Executive Officer, AP Fiber Grid	Member
15	Managing Director, AP Technology Services Ltd.	Member-Convener
16	3-5 Expert Members	Member

7.2.2. Advisory Board

1. The key stake holders of the AP cyber security program include the citizens, industry and academia in the State. Accordingly, there is a need to have an institutional mechanism to incorporate their views with respect to the program/ projects.
2. The Advisory Board may be established as an autonomous body with representations from Key government departments, Industry Association, academic institutions and experts in the areas of governance, information security and related technologies.
3. The Advisory Board will work as the sounding board for the Sub-committees as well as the Apex Committee in taking important decisions with respect to the formulation and implementation of AP-CSF. The group can also serve as an informal “monitoring group” for AP-CSF.

Suggested Composition of the Advisory Board:

1	Principal Secretary ITE&C Department	Chairperson
2	Managing Director, AP Technology Services Ltd.	Member-Convener
3	Industry Experts (Leading technology and cyber experts at national and international level)	Member
4	Industry bodies Think tanks and Associations (Civil Societies)	Member
5	Academician(s)	Member
6	Representatives from Financial Institutions	Member
7	Representatives from Media	Member

Roles and responsibilities of the Advisory Board:

1. Advise on Citizen Needs and requirements
2. Advise on setting up of technical and process standards
3. Design of outcome-oriented impact assessment methodologies
4. Advise on funding strategy
5. Provide Expert Inputs on various elements of AP-CSF

7.2.3. Sub-Committees for Implementation

1. Three program sub-committees would be established to be responsible for operationalizing and implementing AP-CSF under the overall strategy and vision of the Apex Committee. These sub-committees would also include external experts and eminent persons connected with the field of cyber security.
2. The key role for the program sub-committees would include:
 - i. Approve operational policies, guidelines, manuals and formats for activities such as project report preparation, technical standards, business model, knowledge management, project management methodologies, impact assessment, publicity, government business re-engineering etc.
 - ii. Overall responsibility for managing funds of the 3 sub-areas viz. Critical Information Infrastructure, Capacity Building and Forensics
 - iii. Apportioning costs between projects and departments
 - iv. Oversight responsibility for the implementation of the projects and initiatives in each sub-area
 - v. Identify inter departmental issues that require intervention of the apex committee
 - vi. Institute and review program and project audit reports from time to time
3. The sub-committees should meet at least once every quarter or more frequently as per need.

The specific objectives and recommended constitution of the sub committees is given below:

7.2.3.1. Sub-Committee on Critical Information Infrastructure

Objectives:

1. **Secure online services:** Operate a Security Operations Centre that will monitor all possible threats and secure critical information infrastructure
2. Train and educate people on cyber security topics and best practices
3. Establish an assurance ecosystem, ensuring mandatory security audit and compliance to laid down controls
4. Establish and Operate AP-CRT
5. Aid and assist technology implementation of controls

Suggested Composition:

1	Principal Secretary ITE&C Department	Chairperson
2	Chief Executive Officer, e-Pragati	Member
3	Managing Director, AP State Fibrenet Ltd	Member
4	Chief Executive Officer, AP Core Digital Data Authority	Member
5	Director (Communications), IT,E&C Department	Member
6	Representative of the Director General of Police	Member
7	Managing Director, AP Technology Services Ltd.	Member - Convener
8	3 Expert members	Member

7.2.3.2. Sub-Committee on Capacity Building

Objectives:

1. To create a skilled workforce of cyber security professionals with specialized skills
2. To re-skill Academic Faculty in new technologies and tools
3. To generate employment opportunities in cyber security
4. To promote cyber security as a preferred career choice in both the private and public sector

Suggested Composition:

1	Principal Secretary, Higher Education Department	Chairperson
2	Principal Secretary, ITE&C Department	Member
3	Commissioner, Technical Education Department	Member
4	Chief Executive Officer, AP Skill Development Corporation	Member
5	The Chief Executive Officer, APITA	Member
6	Representative of APSCHE	Member

7	Representative of IIDT	Member
8	2 representatives each from Industry and Universities	Member
9	Executive Director, AP Technology Services Ltd.	Member-Convener
10	3 Expert Members	Member

7.2.3.3. Sub-Committee on Cybercrime and Law Enforcement

Objectives:

1. To build cyber security capabilities of Law Enforcement Agencies (LEA)
2. Help in designing and rolling out SOPs for Cyber Security Police stations
3. Partner with private sector to assist in cyber investigations
4. Facilitate participation of police officers in global conferences on cyber security

Suggested Composition:

1	Director General of Police	Chairperson
2	Principal Secretary, ITE&C Department	Member
3	Commissioner, Technical Education Department	Member
4	Additional Director General of Police (CID)	Member
5	Director, AP State Forensics Laboratory	Member
6	Representative of IIDT	Member
7	Executive Director, AP Technology Services Ltd.	Member-Convener
8	3 Expert members	Member

7.3. Supporting guidelines and tool kits

For all the supporting guidelines and toolkit for self-assessment please refer to the APTS website. A unit of APTS will constantly monitor the evolving cyber ecosystem and will publish the guidelines and directives for combating latest threats.

7.4. Nodal body to assist implementation

APTS (Andhra Pradesh Technology Services) will act as nodal body, which can be contacted for any assistance in the implementation of the AP-CSF framework and the associated technology initiatives. It is a State government entity (incorporated in 1986) working under the ITE & C department of Andhra Pradesh, India.

APTS has built capacity and capability to provide cyber security services in both, dedicated and shared services model. AP-CSOC, a state-of-art, cyber security operations center is also operated by APTS, on behalf of the ITE & C department. Organizations' and Departments can reach out to APTS for the following services in the area of cyber security:

- a. Aid and assist in understanding and implementing the framework
- b. Create Policies and procedures, and establish security governance
- c. Conduct risk assessment and identify the gaps
- d. Design security strategy & roadmap

- e. Design security architecture and deploying security solutions
- f. Conduct security tests, audits and exercises
- g. Maintenance of the security infrastructure and processes
- h. Provide skilled manpower and shared infrastructure for capacity building
- i. Security Incident and Event Management
- j. Provide threat intelligence and help in proactive and reactive defense strategies

7.5. Annexure

7.5.1. Unique Identifiers for Controls

A unique identifier has been assigned to each of the controls adopting the following Format:

<Control Universe Section>.<Control Function>.<Control Category><Number Sequence as per list>

For eg. The second control in the Baseline Control (BS) in the Identify Control Function (ID) and Governance Category (GV) will be denoted as shown below:

BS.ID. GV 2